

OT Operational Technology **환경의** **제로트러스트 적용 안내서**



OT Operational Technology 환경의 제로트러스트 적용 안내서



요약

■ [OT 대상 사이버 공격의 양상] OT 대상 사이버 공격은 물리적 피해 뿐만 아니라 사회적 혼란을 초래할 수 있어 국가 지원 해킹조직들이 국가 핵심 인프라 마비를 위해 OT 인프라를 전략적으로 공격하여 국가 안보에 심각한 영향

- IT 대상 침해사고가 주로 데이터 탈취나 서비스 지연에 그치는 것과 달리, OT를 대상으로 한 사이버 공격은 설비 오작동, 생산 중단, 정전, 장비 파손 등 물리적 피해로 직결되어 사회 전반에 훨씬 더 큰 피해 발생
- 제조·에너지·교통·발전 등 핵심 인프라 부문에서 스마트팩토리·원격제어·데이터 분석을 위한 관제 서버 및 클라우드 등 외부 연결성이 증가하면서, 공격 표면이 증가하고 있으며 폐쇄망 중심 보안은 더 이상 실효성을 갖지 못함
- OT 제어 장치를 직접 감염시키는 등 더욱 정교한 방식의 공격들이 등장하고 있으며, 국가 지원 해킹조직들은 전력망·원자력·수도·교통과 같은 국가 핵심 인프라를 마비시키고자 함으로써 사실상 국가 안보에 심각한 영향

■ [OT 보안의 특성] 망분리 등 경계 기반 OT 보안 모델 역시 내부 침투 공격에 노출될 수 있으며, 레거시 장비에 의존하고 가용성과 실시간성을 요구하는 환경의 특성상 취약점 점검 및 보안 기술 적용이 어려움

- 망분리로 인터넷 등 외부와 연결이 되어 있지 않아 안전하다는 인식이 있으나, USB를 통한 물리적 침해, 팀 뷰어 및 소프트웨어 업데이트 등을 통한 내부망 침투 사례 존재
 - Stuxnet은 USB를 통한 물리적 침해를 수행하였고, 미국 올즈마 수도 시설 공격은 팀 뷰어를 통한 내부망 침투, 후쿠이현 몬주 핵 발전소 공격은 소프트웨어 업데이트를 통하여 내부망 침투 수행
 - 망분리에 의존함으로써 내부망에 들어온 주체를 기본적으로 신뢰하는 구조는, 상대적으로 내부에 대한 모니터링 및 가시성 확보 등에 소홀하여 내부 침투 대응이 매우 미흡
- 가용성과 실시간성을 최우선으로 요구하는 환경의 특성상 취약점 점검·보안 패치·보안 장비 설치조차 쉽게 적용하기 어려워 이미 알려진 취약점이 장기간 방치되거나 대응이 지연되는 구조적 한계 존재
 - 보안 패치로 인한 시스템 재부팅 시 설정 데이터가 초기화될 수 있고, 아주 작은 확률이지만 시스템 장애가 발생할 가능성으로 인해 취약점 패치가 지연되거나 아예 방치되는 경우 존재
 - 보안 시스템이 (아주 작은 확률이라도) 정상 패킷을 차단할 경우 OT 시스템에 심각한 장애를 유발할 수 있어 필터링 기능을 적극적으로 활용하지 못하고, 실시간성 보장을 위해 강한 인증 및 암호화 기술의 적용이 어려워, 주로 수동적 보안 기법에 의존하는 한계
 - 오래된 PLC/RTU/SCADA 장비 등 OT 시스템은 기본적인 보안 기능조차 탑재되지 않아 외부 공격에 그대로 노출되거나 제어 명령 위변조, 불법 접근에 취약한 경우가 많으며, IT와 다른 복잡한 구조하에 다양한 장비가 혼재되어 있어 자산 식별 및 보안 정책의 일관된 적용이 어려움

■ [OT 특화 제로트러스트의 필요성] 내부 침투를 가정하는 제로트러스트 전략은 경계기반 보안에 의존하는 OT 환경에서도 횡적 이동 및 공격 완화에 효과적일 것으로 판단되나 OT 환경이 갖는 특성으로 인하여 IT와 다른 제로트러스트 전략 필요

- IT 제로트러스트는 리소스·데이터 접근제어를 위한 지속적인 인증 및 동적 검증, 비정상 접근 차단, 보안 패치 등을 통하여 탐지 및 대응을 강화하고 있으나, 이로 인한 지연, 정상 패킷 차단 등이 발생

구분	IT 제로트러스트에서의 가정	OT 환경의 제약·한계
목표/우선 순위	• 보안·기밀성 중심, 일정 수준의 지연·단기 서비스 중단은 허용 가능	• 가용성·실시간성 최우선, 제어 신호 지연 시 생산 중단·안전사고로 직결
패치·업데이트	• 정기적 패치·보안 기능 확장을 전제로 안정적 운영 가능	• 레거시 시스템으로 인해 패치 지연·적용 제한, 취약점 방지 위험
네트워크 구조	• 단일 네트워크·클라우드 중심 접근제어 구조	• Purdue 모델 기반 계층 구조로 레벨별 자산 특성 따라 보안 요구 상이
로그·가시성	• 표준 프로토콜 기반 중앙 로그·SIEM 분석 가정	• 산업용 프로토콜 특성으로 기존 IT 보안 솔루션과 호환성이 낮아, 네트워크·자산 가시성 확보 제한

■ [국내외 OT 특화 제로트러스트 정책] 미국 등 글로벌 주요국은 OT 특화 제로트러스트 전략을 추진하고 있으나, 국내에는 현재 개념 정립이 이루어지지 않음

- 미국 원자력규제위원회(NRC)는 SMR(소형모듈원자로)¹⁾ 등 차세대 원자로에 디지털 기술이 도입되면서 기존 보안 아키텍처 한계 인식 및 제로트러스트 도입 방안 연구 중에 있으며, 클라우드보안 협회(CSA)는 중요기반시설 및 ISC 환경에서 제로트러스트 적용 가이드 연구 및 문서 발간
- 미 국방부는 OT 환경의 특성을 반영한 제로트러스트 전략을 2025년 11월 발표하였으며 OT를 운영 계층과 프로세스 제어 계층으로 구분하고 총 105개의 제로트러스트 활동(84개 목표 수준 활동, 21개 개선 수준 활동)에 대한 결과를 설명
- 일본과 싱가포르 등은 OT 보안 규제와 가이드를 강화하여 보안성 향상
- 국내 OT 보안은 국가 차원의 공통 지침과 발전·전력·제조 등 산업별 특화 가이드라인을 통해 최소 보안수준과 현장 적용성을 확보하고 있으나 제로트러스트 전략 적용 및 검증이 이루어지지 않았으며, 상기 해외 사례들은 차후 국내 OT 제로트러스트 로드맵 수립 및 거버넌스 모델 구축에 참조 가능

1) SMR(Small Modular Reactor, 소형모듈원자로): 소형 원자로를 공장에서 모듈 형태로 제작한 뒤, 현장에서 조립하여 건설 기간과 비용을 단축하고 안전성과 유연성을 높인 원자로

■ [OT 특화 제로트러스트 적용 방안] 가용성과 실시간성을 중시하는 OT 고유 특성을 고려하여 OT 제로트러스트 핵심 원칙, 고려 사항 도출 및 OT망에 적합한 제로트러스트 아키텍처 설계 필요

- OT 특화 제로트러스트를 위한 핵심 원칙으로는 실시간성·가용성 유지, OT 장비의 독립성 유지라는 OT의 특성과 함께 OT·IT 전역에서의 침해 가정, 지속적 모니터링이라는 제로트러스트 원칙이 공통적으로 적용되어야 함

핵심원칙	설명
실시간성·가용성 유지	• 인증·검증 및 소프트웨어 패치 과정에서 지연이나 중단이 발생하지 않도록 안전 장치와 이중화 구조를 마련해야 함
OT 장비의 독립성 유지	• 현장 장비는 외부 서버나 네트워크 상태와 관계없이 최소한의 정책 판단 능력을 유지하며, 자율적으로 신뢰 결정을 지속할 수 있어야 함
OT·IT 전역에서의 침해 가정	• OT와 IT망 상관없이 공격자가 이미 내부에 있다고 전제하고, 마이크로세그멘테이션·DPI (Deep Packet Inspection)·이상 행위 기반 탐지 등을 통해 횡적 이동을 차단해야 함
지속적 모니터링	• OT 트래픽의 결정적 특성을 활용해 기준선을 마련하고, 이상 징후를 탐지할 수 있는 중앙 로그 관리·SIEM 체계를 마련해야 함

- IT망과 OT망을 병행 운영하는 조직에서 두 환경에 대한 일치된 보안 정책 제공, 관리 혼선 최소화 등을 위하여 IT-OT를 동시에 아우르는 제로트러스트 핵심 요소 및 기능 요구사항 정의 필요
- OT 특화 제로트러스트 도입을 위한 기관별 로드맵의 경우 CSA를 참조한 5단계 구조를 적극 고려
 - ① OT 자산 식별 및 보호 대상 정의, ② OT 트래픽 및 운영 흐름 가시화, ③ 제로트러스트 아키텍처 설계, ④ 제로트러스트 정책 수립 및 구현, ⑤ 지속적 모니터링 및 유지관리
 - OT 환경에서 제로트러스트는 일괄 구축이 아닌 보호 대상 소규모 정의 후 점진적·단계적 검증 및 확장을 통해 안정성과 효율성을 함께 확보해야 함

■ [OT 특화 제로트러스트 도입 시사점] OT 보안 강화를 위한 국가 차원의 전략 수립, 제도·정책 고도화, 신기술 기반 대응 역량 강화 필요

- OT 보안은 국가안보 차원에서 접근해야 하며, 환경 변화에 따르는 국가 차원의 OT 제로트러스트 전략 수립을 통하여 고도화되는 위협에 대응 필요
- 미국 등 글로벌 선진국 역시 OT 보안을 위하여 제로트러스트 도입을 천명하고 있는 것과 같이, 국내에서도 기존 제도를 보완함으로써 개별 지침이나 기술이 아닌 운영·정책·관리 체계를 포괄하는 프레임워크로 동작할 수 있는 제도·정책 마련 및 기술 역량 강화 필요

OT Operational
Technology 환경의
제로트러스트 적용 안내서



OT Operational
Technology **환경의**
제로트러스트 적용 안내서



CONTENTS

제1장 서론

1-1 문서 발간 배경	8
1-2 문서 발간 목적	9
1-3 문서 구성	9

제2장 OT 및 제로트러스트 개요

2-1 OT(운영 기술)	10
2-2 제로트러스트(Zero Trust)	15

제3장 OT 특화 제로트러스트(OT ZT)의 필요성

3-1 OT 위협 사례	20
3-2 OT 환경 특성 및 고유 취약점	25
3-3 OT 환경에서의 제로트러스트 필요성	28

제4장 국내외 OT 특화 제로트러스트 정책 동향 및 적용 사례

4-1 해외 동향	31
4-2 국내 동향	45

제5장 OT 특화 제로트러스트 적용 방안

5-1 OT ZT 핵심 원칙 및 고려 사항	49
5-2 OT ZT 적용 방안	50
5-3 OT ZT 도입 로드맵	54

제6장 결론

■ 용어 정의	61
■ 참고문헌	63

제1장 서론

1-1 문서 발간 배경

■ OT(Operational Technology)/ICS(Industrial Control System)는 제조, 에너지, 발전, 운송 등 국가 핵심 인프라의 안정적 운영을 담당하는 핵심 기술 영역으로, 산업 현장의 설비·공정을 실시간으로 제어하고 운영 효율을 극대화하는 데 필수적

- 최근 산업계 전반에서 디지털 전환(Digital Transformation)과 스마트팩토리, 원격진단 및 유지보수, 원격제어 등 운영 효율성·생산성 향상을 위한 외부 연결이 증가하면서 OT 환경은 더 이상 완전한 폐쇄망 구조를 유지하기 어려운 상황에 직면
- 또한, 기존 망분리 중심 폐쇄망 보안 전략은 공격 경로가 원천 차단될 것이라는 믿음으로 내부 네트워크 방어 및 가시성에 소홀하게 되어 내부 위협, 공급망 공격 등 내부 침투 공격에 취약할 뿐만 아니라, 원격진단·유지보수·제어를 위한 외부 연결이 새로운 침투 경로 역할을 할 가능성이 생기고 있음
- 최근 IT 기반 기업·기관 업무망 환경에서는 내부·공급망 위협에 대해 위험을 완화할 수 있는 제로트러스트 전략이 주목을 끌고 있으며, 많은 곳에서 제로트러스트 전략을 만족하기 위한 최신 보안 기술을 도입하고 있음
- 이에 따라 OT 환경에서도 “신뢰하지 말고, 항상 검증하라(Never Trust, Always Verify)”는 원칙을 기반으로 하는 제로트러스트(Zero Trust) 보안 모델 적용이 강하게 요구되고 있음

■ 기존 IT 환경에서 최근 각광받고 있는 제로트러스트 보안 모델을 변형·구성하여 OT 환경에 적합한 제로트러스트 보안 모델에 대한 가이드 제정 필요

- 제로트러스트 보안 모델은 내부에 이미 공격자가 존재할 수 있음을 가정한다는 면에서 기존보다 높은 수준의 보안 기술을 요구하고 있으나, OT/ICS 환경은 적용 기술(시스템, 통신 방식 등)이 다르고 실시간성·가용성·제어안정성을 핵심 요구사항으로 둔다는 면에서 IT 환경과 상이하여 기존 제로트러스트 보안 모델의 직접적 적용에 한계가 있어 OT 특성에 맞춘 변형·보완 필요
- OT/ICS 환경을 위한 보안 책임자 및 실무자는 제로트러스트 보안 모델 구축 방안에 대한 사례, 가이드 등이 존재하지 않아 도입이 어려움

1-2 문서 발간 목적

■ 본 문서의 목적은 OT 및 제로트러스트 보안 모델에 대한 기본적인 이해 제고 및 국가 핵심 인프라 보호를 위한 OT 제로트러스트 적용 전략 제시

- 보안 책임자·실무자 뿐만 아니라 보안에 대한 전문성이 부족한 경영진(C레벨) 및 일반 직원들도 OT 보안의 중요성과 특수성을 이해할 수 있도록 기본 개념 및 기술적 특성 소개·설명
- 제로트러스트의 핵심 원리와 아키텍처를 소개하고, 이를 OT 환경에 적용하기 위한 세부 기술 및 단계별 접근 전략 제시
- 국내외 정책·표준 동향과 향후 로드맵 및 시사점을 제시하여, 공공·민간 부문에서의 OT 제로트러스트 도입·확산을 위한 기반 자료로 활용될 수 있도록 함

1-3 문서 구성

■ 본 문서는 OT 환경에서 제로트러스트 보안 모델을 도입하기 위한 정책적·기술적 방향성을 제시하기 위해 총 6장으로 구성

- 제1장에서는 문서 발간의 배경과 목적 설명 및 OT 제로트러스트 연구 필요성과 본 문서 구성 체계 제시
- 제2장은 OT와 IT(Information Technology)의 구조적 차이, 제로트러스트의 핵심 원리 및 아키텍처 구성 요소 등 OT와 제로트러스트에 대한 개략적인 소개
- 제3장에서는 최근 OT 환경을 대상으로 한 사이버 위협 사례를 분석하고, OT 환경 특성 및 고유 취약점으로 인한 한계를 제시함과 동시에 OT 환경에 특화된 제로트러스트 접근의 필요성 제시
- 제4장에서는 미국, 캐나다, 일본 등 주요 국가 및 국내 OT 제로트러스트 정책 동향을 분석하고 적용·실증 사례 확보의 필요성 언급
- 제5장에서는 OT 환경에서의 제로트러스트 적용 방안을 제안하기 위하여, OT 환경에서 제로트러스트를 구현하기 위한 단계별 접근 전략과 기술 구성 요소, 그리고 Zone-Conduit 모델 기반의 세그멘테이션 및 접근제어 방안 등을 포함하는 도입 로드맵을 구체적으로 제시
- 제6장에서는 본 문서에서 다룬 주요 논의를 종합하여, 향후 OT 제로트러스트 도입·운명을 위한 제도적, 기술적, 조직적 방향성 제언

제2장 OT 및 제로트러스트 개요

2-1 OT(운영 기술)

- ▶ OT는 산업 설비와 공정을 실시간으로 제어·운영하는 기술로, 전력·교통·에너지 등 국가 주요 인프라의 안정적 운영에 핵심적 역할 수행
- ▶ OT 환경은 IT 환경과 달리 실시간성, 무중단 가용성, 장기 운용, 전용 프로토콜 등 상이한 기술적 특성을 지니며, SCADA·DCS·PLC 등으로 구성됨
- ▶ IEC 62443 등 국제 표준은 OT 보안을 자산·시스템·제품 전주기에서 체계화한 국제 표준으로, Zone-Conduit 모델에 기반한 다계층 보안 통제와 보안 수준 관리 체계를 제시하여 조직의 일관된 보안 운영 지원

■ OT는 하드웨어와 소프트웨어를 활용하여 산업용 장비를 제어·운영하는 기술로써 제조, 에너지, 교통, 스마트 시티 등 다양한 산업에서 활용

- OT는 센서, 제어기, 액추에이터 등과 직접 연결되어 현장의 설비와 공정을 실시간으로 제어·감시하는 역할 수행
- OT의 대표적 범주에는 산업제어시스템(Industrial Control Systems, ICS), BAS(Building Automation Systems), ITS(Intelligent Transportation Systems) 등 포함
- OT는 IT와 대비되는 개념으로, OT는 산업 장비와 공정을 직접 제어·운영하는 기술인 반면 IT는 데이터 처리와 정보 관리에 중점을 둠

<표 1> 운영기술과 정보기술 차이

비교 항목	OT (Operational Technology)	IT (Information Technology)
사고 영향	사고 발생 시 인명·물리적 피해와 직결	사고 발생시 경제적 피해 발생
네트워크 성능	강한 실시간 요구사항	전체 성능(throughput)에 초점
가용성	무중단 운영되어야 함	서비스 대부분은 시급성을 가지지 않음
OS 및 시스템	다양한 이기종의 HW, SW로 구성(VxWorks 등의 임베디드 OS)	범용 OS 사용(Window, Linux)
운용주기	장기간의 운용 주기(10~30년)를 가지며 유지보수 어려움	상대적으로 단기간의 운용 주기를 가짐
프로토콜	제어 표준 및 비공개 전용 프로토콜 사용	범용 프로토콜 사용

출처) 저자 재구성

- OT는 물리적 환경과 직접 상호작용하며 상수도, 교통, 전력망, 발전소 등 국가 주요 인프라 운영에 필수적으로 적용

<표 2> 분야별 OT 적용 시스템 예시

분야	OT 적용 시스템 예시
전력 및 에너지	• (한국전력) 송·변전 SCADA 시스템, 배전자동화 시스템, 변전소 집중감시제어 시스템 • (전력거래소) 전력계통운영시스템, 전력거래시스템 • (한국수력원자력 및 5개 발전사) 발전소제어시스템 • (한국가스공사) 천연가스배관망 원격감시제어시스템 • (대한송유관공사) 송유관 원격감시제어시스템
수자원 분야	• (한국수자원공사) 수도통합운영시스템, 발전통합운영시스템, 댐홍수경보시스템 • (지자체) 정수제어시스템
철도 분야	• (한국철도공사) 열차집중제어시스템, 전력계통집중원격감시시스템 • (서울메트로, 서울도시철도공사) 열차신호 제어시스템
항공 분야	• (한국공항공사) 항로관제시스템 • (인천국제공항공사) 수하물제어시스템, 공항운영정보시스템, 서울접근관제시스템
교통 분야	• (한국도로공사) 도로전광표지시스템 • (경찰청) 교통신호제어시스템
기타 분야	• (선박) AIS(선박자동식별시스템), 화물 제어 및 모니터링 시스템, 전자 해도 표시 시스템 등 • (항만) 항만 자동화 설비 제어시스템, 물류 관리 시스템, 항만 운영 관제 시스템 등 • (스마트시티) 건물 에너지 관리 시스템 (BEMS), 스마트 가로등 시스템 등 • (석유·가스) 시추, 정유, 가스 파이프라인 제어시스템 등

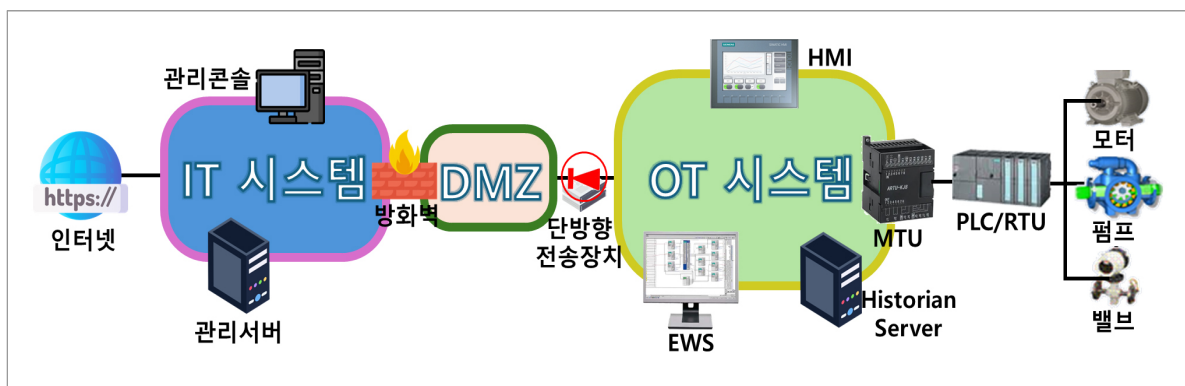
출처) 저자 재구성

■ OT는 산업 장비의 제어·운영을 위해 다양한 구성 요소와 외부와 망이 분리되어 있는 네트워크 환경으로 이루어짐

- OT는 SCADA, DCS, PLC, RTU 등 다양한 산업제어시스템으로 구성
 - SCADA(Supervisory Control And Data Acquisition): 광범위하게 분산된 자산을 원격에서 모니터링·제어하기 위한 시스템으로, 전력 송배전망, 수자원, 가스·오일 유통, 대규모 인프라 관리에 주로 사용. 일부 발전·산업 시설에서는 SCADA가 보조 감시계층으로 사용되기도 함
 - DCS(Distributed Control System): 여러 위치에 분산된 제어 장치를 중앙 제어실에서 통합 관리하여 전체 시스템을 모니터링하고 제어하는 시스템
 - PLC(Programmable Logic Controller): 필드 디바이스(센서, 액추에이터 등)와 연결되어 공정을 자동 제어하는 핵심 제어 장치
 - * DCS는 대규모 연속 공정의 중앙 집중적 제어·모니터링에 적합하며, PLC는 장비·설비 단위의 로직 기반 시퀀스 제어나 빠른 디지털 제어에 주로 사용
 - RTU(Remote Terminal Unit): 현장 계측기에서 수집한 데이터를 SCADA, HMI 등으로 전송하는 장치
 - HMI(Human Machine Interface): 기계가 인간과 통신할 수 있도록 해주는 사용자 인터페이스로 운영자가 시스템 상태를 직관적으로 확인하고 제어 명령 입력에 사용

- EWS(Engineering Work Station): PLC와 같은 발전소의 제어시스템을 설계, 구성, 유지보수하는 데 사용하는 워크스테이션
- MTU(Master Terminal Unit): 현장(원격) 장치로부터 데이터를 수집하고 제어 명령을 내려보내는 역할을 수행, 다수의 RTU와 연결되어 정보를 수집
- Historian: 데이터를 장기간 저장하고 분석하기 위한 데이터베이스 시스템
- Field Device: 센서, 액추에이터, 밸브, 모터, 계측기 등과 같은 현장 장치로써 PLC/RTU에 연결되어 데이터를 전달하거나 제어 명령을 수행

<그림 1> OT 환경 내 구성 요소 현황

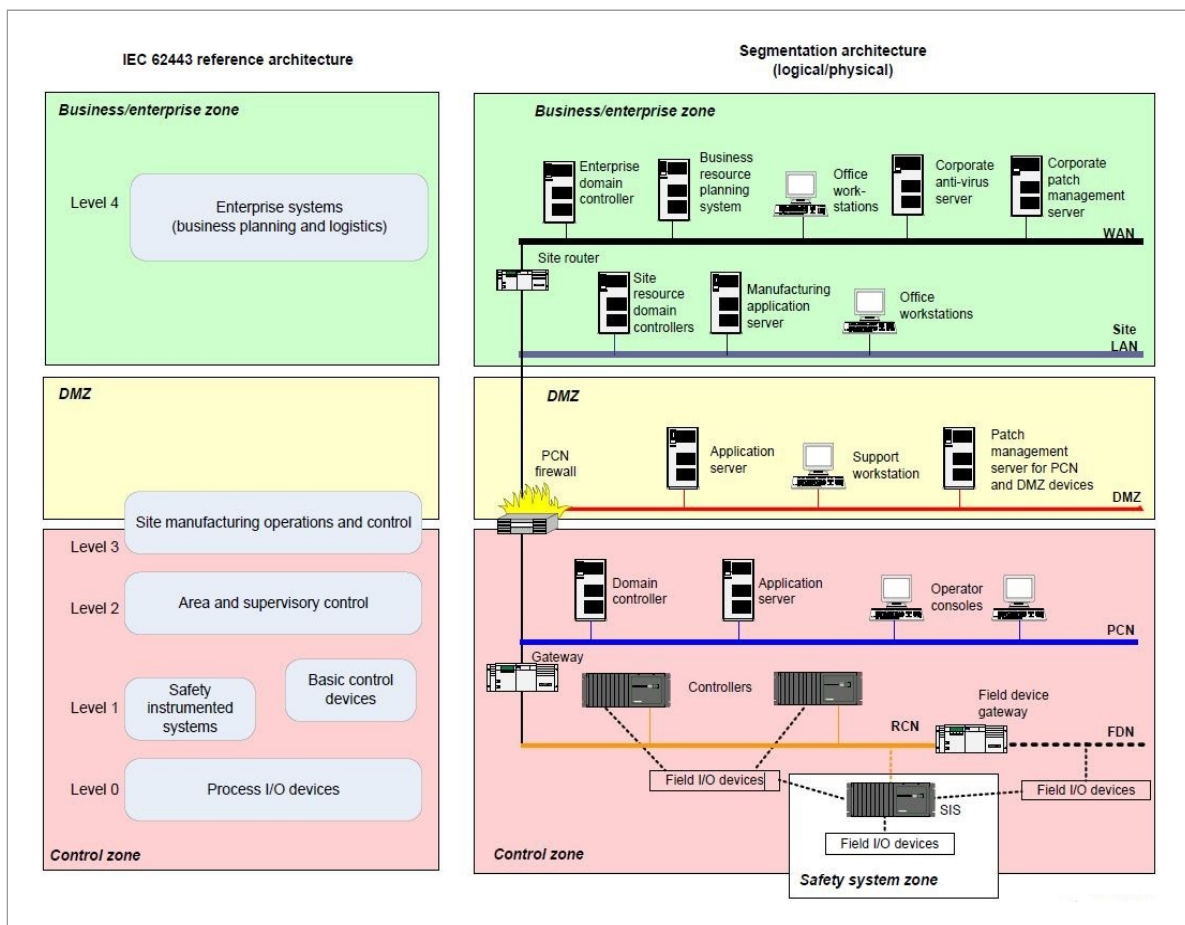


출처) 저자 작성

- OT 환경은 일반적으로 IT망(업무망) 환경과 분리되어 있으며 에어갭(Air-Gap)에 기반한 망분리와 네트워크 세그멘테이션을 통한 내부망으로 구성
 - OT망은 필드 디바이스 망, 제어망으로 구성되며 IT망(업무망)과 물리적·논리적으로 분리되어 외부망 연결을 최소화하여 보안성을 강화함
 - 망분리는 방화벽, 일방향 자료 전달 장치 등을 사용하여 외부에서 내부의 데이터 유입을 차단
 - * 일방향 자료전달 장치는 물리적·논리적으로 한 방향으로만 데이터 전송이 가능하게 하여 내부에서 외부망으로만 데이터를 전달하는 기술
- 전통적으로 OT망은 Purdue 모델을 이용해 Level 0부터 Level 4까지 네트워크 계층을 구분(Level 4: IT 환경인 업무망, Level 0~Level 3: OT망)
 - Level 4: 비즈니스 망으로써 기업의 IT 시스템들이 위치하는 계층, OT망에서 올라온 데이터를 활용하여 경영, 자원 관리 등을 수행함
 - DMZ 망: 비즈니스 망과 OT망 사이에 위치하는 망으로써 데이터 교환 서버, 패치관리 서버, 백신 관리 서버, 가상 사설망(VPN) 시스템 등이 위치
 - Level 3: 생산 관리, 운영 시스템이 위치하는 계층으로 Historian, MES(Manufacturing Execution System) 등이 존재
 - Level 2: 운영자 인터페이스가 존재하는 계층으로 HMI, SCADA 시스템, EWS 등이 존재하여 실시간 모니터링, 제어, 경보 처리 등 운영자가 개입하는 영역

- Level 1: 센서/액추에이터와 직접 연결된 제어 장치들이 위치하는 계층으로 PLC, RTU와 같은 장치들이 존재
- Level 0: 실제 산업 현장의 물리적 설비와 프로세스가 위치하는 계층으로 센서, 액추에이터, 모터, 밸브, 펌프 등 물리적 장치들이 존재
- Purdue 모델*은 IEC 62443 표준에서 산업제어시스템 네트워크 아키텍처 및 보안 영역을 정의하는 개념적 기반으로 활용
 - * Purdue 모델: Purdue 대학에서 1990년대 초 개발한 모델로, ICS 환경을 여러 레벨로 계층화하여 제어 영역과 비즈니스 네트워크 간의 경계를 명확히 정의하는 산업제어시스템 참조 아키텍처²⁾
 - Purdue 모델은 OT/ICS 구성 요소 간 상호 연결 및 의존성을 계층 구조로 표현하는 참조 모델로 자리 잡음(그림 2 참조)
 - 현재는 다양한 표준과 기관에서 요구되는 환경에 맞게 수정·확장하여 활용되고 있음

<그림 2> OT 구성 요소 및 네트워크 구조

출처) IEC 62443-2-1, "Security program requirements for IACS³⁾ asset owners"

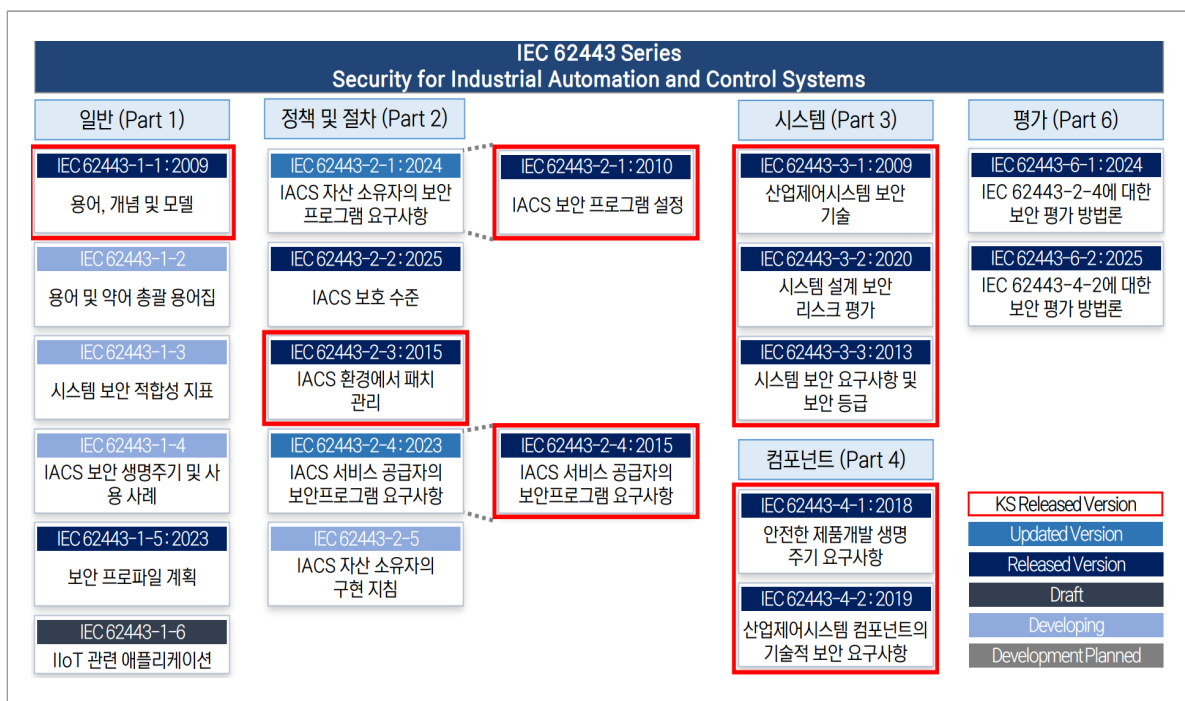
2) Garton, David., "Purdue model framework for industrial control systems & cybersecurity segmentation", US Department of Energy 14 (2022): 2022-10.

3) IEC 62443에서는 산업제어시스템을 가리키는 용어로 IACS(Industrial Automation and Control Systems)를 사용

■ 2009년 발간된 「IEC 62443」 표준 시리즈는 ICS·OT 보안을 위한 국제 표준으로, 대부분 국가에서 ICS 및 OT 환경 보안 지침으로 활용

- 자산 소유자·시스템 통합자·제품 공급자가 각각 따라야 할 절차와 기술적 요구사항을 구체적으로 제시하며, 보안 수준(Security Level)과 기본 요구사항(Foundational Requirement)을 통해 전 생명주기 보안을 체계화함
- 네트워크를 Zone-Conduit 모델⁴⁾에 따라 구분해 보안 경계를 정의하고, 영역 간 통신 흐름을 통제하여 침입 확산을 최소화하도록 요구함
- 또한, 사용자 인증, 권한 부여, 로그 관리, 데이터 무결성 보장 등 핵심 통제를 규정하여 운영 과정에서 발생할 수 있는 위협을 다계층적으로 방어하도록 규정
- 더불어 조직은 보안 수준(Security Level)을 자산의 중요도와 위협 시나리오에 따라 설정하고, 그에 맞는 기술적·관리적 조치를 단계적으로 적용함으로써 국제적으로 통용 가능한 보안 역량 확보를 요구
- IEC 62443 표준 시리즈는 특정 조직에 국한되지 않고 제품 개발, 시스템 구축, 운영·유지보수 등 공급망 전체에 걸쳐 일관된 보안 적용을 보장하는 특징을 가짐

<그림 3> IEC 62443 표준 시리즈



출처) 서정택, "OT 사이버보안위협 및 대응방안", G-PRIVACY 2021 컨퍼런스

4) 산업제어시스템을 보안 구역(Zone)으로 나누고, 각 구역 간의 통신 경로를 Conduit(통로)으로 정의하여 경계와 제어 지점을 설정하는 모델

2-2 제로트러스트(Zero Trust)

- ▶ 제로트러스트는 경계기반 보안 모델의 한계점을 보완하기 위해 등장한 현대 보안 패러다임으로, 미국 주도의 정책·표준을 축으로 발전해 온 개념임
- ▶ 제로트러스트 아키텍처는 논리적으로 PDP/PEP/PIP로 구성되며, 중앙 정책의 일관 집행, 상태 기반의 지속 검증, 최소 권한 접근을 통해 운영되는 정책 중심 모델임
- ▶ 미국과 한국을 포함한 다수 국가가 제로트러스트 관련 정책을 제도화·시행 중이며, 이는 조직 보안의 핵심 프레임워크로서 제로트러스트의 전략적 중요성 및 도입 불가피성을 시사

■ 제로트러스트(Zero Trust)는 ‘아무것도 신뢰하지 말고 항상 검증하라(Never Trust, Always Verify)’라는 원칙에 따라 네트워크 경계를 신뢰 판단의 전제로 삼지 않고 위치와 관계없이 모든 접근을 지속적으로 검증하며 최소 권한만 부여하도록 요구하는 보안 패러다임

- 기업망을 보호하기 위해 경계를 설정하고 방화벽과 같은 보안 솔루션을 배치하는 전통적 경계 기반 보안 모델은 내부 리소스 보호에 다음과 같은 한계가 존재함
 - (네트워크 환경 다변화) 기업·기관의 규모 확대로 다양한 네트워크 구성이 도입되고 재택근무 확산으로 외부 접속이 급증하면서, 비용과 보안 복잡도가 증가
 - (클라우드 활성화) 기존 온프레미스 중심의 기업망은 관리·유지보수 비용 절감, 운영 편의성, 신규 서비스와 AI 기술 도입 등을 이유로 클라우드 환경으로 빠르게 전환되고 있으며, 이 과정에서 기업·기관망은 점점 복잡해지고 내·외부 경계가 모호해지는 문제가 발생
 - (횡적 이동) 경계 기반 보안 모델은 내부 사용자를 상대적으로 신뢰하는 구조를 가지고 있어 내부망에 침투한 공격자가 악성 활동을 확산시키는 횡적 이동에 매우 취약한 한계를 보임
- 이에 따라 기존 경계 기반 모델의 한계를 극복하기 위해 동적 접근제어, 지속적 검증 및 최소 권한 부여를 핵심으로 하는 새로운 보안 모델의 필요성이 제기됨
- 2010년, Forrester Research의 수석 애널리스트인 John Kindervag는 기존 경계 기반 모델의 위험성을 지적하며 기업·기관망에서 더 엄격한 접근제어의 필요성을 강조하기 위해 제로트러스트 모델을 제안함
- 2014~2015년, 미국 연방정부 인사관리처(OPM)에서 약 2,150만 명의 개인정보가 유출되는 사건이 발생하였으며, 미 하원 감독개혁위원회는 1년여간의 조사를 거쳐 2016년 발행한 보고서 「The OPM Breach: How the Government Jeopardized Our National Security for More than a Generation」에서 처음으로 제로트러스트를 향한 연방 정보보안 강화 노력을 권고함
- 2020년, NIST는 「Zero Trust Architecture(SP 800-207)」 발표를 통하여 제로트러스트에 대한 정의, 원칙과 함께 유스케이스, 보안 위협, 전환 단계 등 정의하였으며, 이 문서는 사실상 전 세계적으로 제로트러스트의 표준으로 인식되고 있음

- 2022년, 미 예산관리실(OMB)은 「Moving the U.S. Government Toward Zero Trust Cybersecurity Principles(M-22-09)」를 발표하면서 연방기관에 2024년까지 제로트러스트 아키텍처 전환을 의무화하고, 신원·기기·네트워크·애플리케이션·데이터 5개 핵심 요소별 목표를 제시함
- 2022년, 미 국방부(DoD)는 「DoD Zero Trust Strategy」를 발표하면서, 국방부 전역에서 2027년까지 Target Level ZT를 구현하고, 2032년까지 Advanced ZT를 구현하는 것을 목표로 하며, 7대 핵심 요소 기반의 세부 목표와 자원 투입 계획을 수립함
- 2023년, CISA는 「Zero Trust Maturity Model 2.0」⁵⁾을 발표하면서, 연방기관 중심 성숙도 모델을 제시했으며, 이 모델은 외부 파트너, 이해 관계자 및 서비스 제공자 등에 제로트러스트가 어떻게 반영되어야 할지 고려해야 하는 모델이라고 언급함
- 2024년, DoD는 「DoD Zero Trust Overlays」 발표를 통해 NIST SP 800-53 보안 통제를 제로트러스트 관점에서 재구성하여 국방 분야 시스템 심사·인증 시 적용할 수 있는 구체적 기준을 마련함
- 2025년, NIST는 「Implementing a Zero Trust Architecture(SP 1800-35)」 마지막 버전 발표를 통해 제로트러스트 아키텍처를 실제 환경에 구현하기 위한 참조 설계·기술 구성 요소·테스트 시나리오를 제공함

■ **국내 제로트러스트 가이드라인 1.0에서는 기업·기관이 제로트러스트 패러다임을 실질적으로 도입 시 참고할 수 있는 총 6가지 기본 원리를 정의함**

- 제로트러스트 가이드라인 1.0은 다음 <표 3>의 제로트러스트 원리에 따라 제로트러스트 아키텍처를 구성하는 것을 제안 (Forrester, Google 등 기업 보고서, CSA SDP, NIST SP 800-207, DoD 제로트러스트 참조 아키텍처 등 참조)

<표 3> 제로트러스트 기본 원리

6가지 제로트러스트 기본 원리
가. 기본 원칙: 모든 종류의 접근에 대해 신뢰하지 않을 것 (명시적인 신뢰 확인 후 리소스 접근 허용)
나. 일관되고 중앙 집중적인 정책 관리 및 접근제어 결정, 실행 필요
다. 사용자, 기기에 대한 관리 및 강력한 인증
라. 리소스 분류 및 관리를 통한 세밀한 접근제어 (최소 권한 부여)
마. 논리 경계 생성 및 세션 단위 접근 허용, 통신 보호 기술 적용
바. 모든 상태에 대한 모니터링, 로그 및 이를 통한 신뢰성 지속적 검증, 제어

출처) 과학기술정보통신부 등, “제로트러스트 가이드라인 1.0”

- 가. 기본 원칙: 모든 종류의 접근에 대해 신뢰하지 않을 것
 - 모든 리소스 접근은 기본 거부를 원칙으로 하며, 인증을 거친 주체에게만 제한적으로 허용함
 - 인증 후에도 세션 탈취·내부자 공격 가능성이 있으므로 지속 모니터링과 추가 인증·세션 종료 등의 대응이 필요함

5) 버전 1.0은 2021년에 발표

• 나. 일관되고 중앙 집중적인 정책 관리 및 접근제어 결정, 실행 필요

- 기업은 리소스 접근에 대해 중앙 집중적이고 일관된 정책 관리·접근제어를 수행해야 하며, 정책 관리 지점이 분산 되면 신규 주체·리소스 추가 시 일관성 있는 정책 적용이 어려움
- 접근 결정·실행 지점이 분산되어 있더라도 반드시 중앙 정책에 따라야 하며, 예를 들어 퇴사자의 계정은 모든 리소스 접근 시도에서 일관되게 거부되어야 함

• 다. 사용자, 기기에 대한 관리 및 강력한 인증

- 사용자는 등록된 기기와 애플리케이션을 통해 기업 리소스에 접근해야 하며, 사용자 식별·인증뿐 아니라 기기 정보와 보안 상태 관리가 필수적임
- 등록되지 않았거나 보안 상태가 불확실한 기기는 접속 차단, 접근 범위 제한, 추가 인증 요구 등의 방식으로 통제해야 함

• 라. 리소스 분류 및 관리를 통한 세밀한 접근제어 (최소 권한 부여)

- 기업 리소스는 데이터, 서비스, 하드웨어, 외부망 등 다양한 계층으로 분류되며, 직급·보안 상태·시간 등 조건에 따라 차별화된 접근제어 정책이 필요함
- 제로트러스트 아키텍처 담당자는 리소스를 명확히 분류하고 주체별 요인에 따라 세밀하게 접근을 제어해야 하며, 이를 통해 최소 권한 부여와 횡적 이동 차단이 가능함

• 마. 논리 경계 생성 및 세션 단위 접근 허용, 통신 보호 기술 적용

- 접근 주체는 허용된 범위를 넘어 다른 리소스에 접근할 수 없어야 하며, 이를 위해 소프트웨어 정의 경계 등 논리적 경계를 적용하고 세션 단위 접근만 허용하여 장시간 접속이나 자동 권한 확장은 지양해야 함
- 리소스 접근 시에는 네트워크 위치와 무관하게 기밀성과 무결성을 보장하는 보호 기술을 적용하여, 세션 탈취·패킷 위변조 등 공격 시도에 대비해야 함

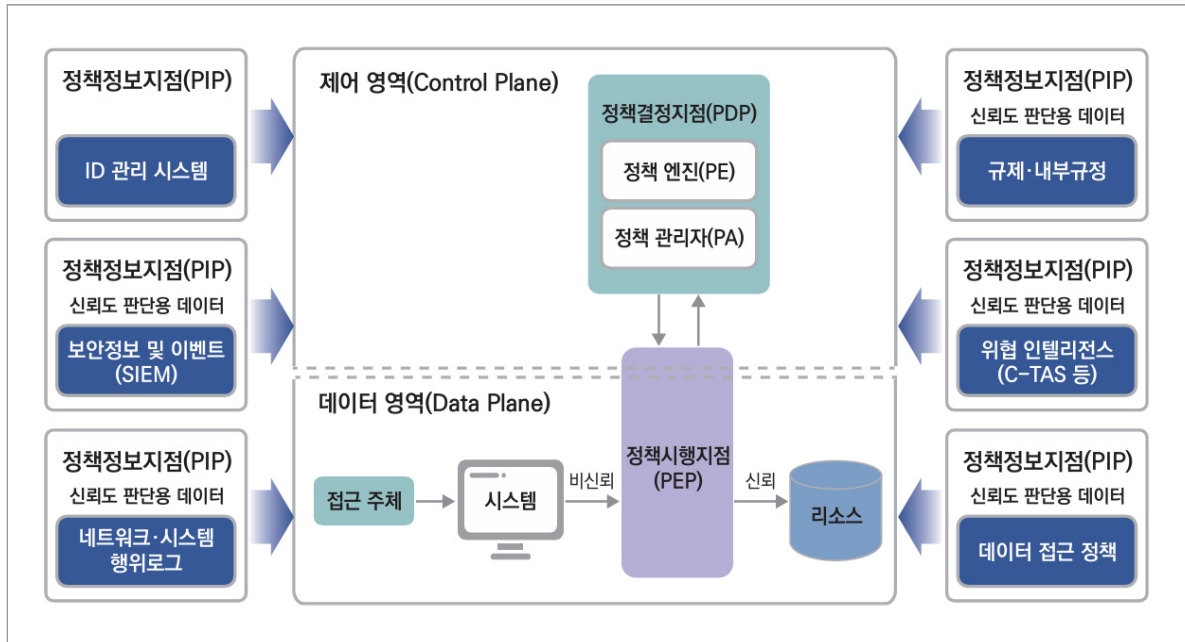
• 바. 모든 상태에 대한 모니터링, 로그 및 이를 통한 신뢰성 지속적 검증, 제어

- 모든 상태란 접근 주체, 리소스, 정책 서버의 조건 전반을 포함함. 시간, 위치, 기기 보안 상태, 접속자 수, 데이터 접근 횟수, 트래픽 양 등이 이에 해당함
- 이러한 상태 정보를 실시간 모니터링하고 로그로 기록하여 수치적·시각적으로 파악 및 사후 감사가 가능해야 함

■ 제로트러스트 아키텍처(Zero Trust Architecture)는 제로트러스트 철학을 기반으로 컴포넌트 간 관계와 워크플로우 설계, 접근 정책을 포함하여 지속적 검증과 최소 권한 원칙을 구현하는 보안 아키텍처

- 기업망이 제로트러스트 아키텍처를 실현하기 위해서는 접근 주체가 리소스에 접근하는 것에 대해 허용/거부 정책을 다루어야 하며 가장 핵심 기능은 접근제어 정책임
- 이러한 접근제어 정책이 실현되기 위해 NIST SP 800-207을 참고하여 국내 제로트러스트 가이드라인 1.0/2.0에서는 제로트러스트 아키텍처 논리 구성 요소를 제시함

<그림 4> 제로트러스트 아키텍처 보안 모델 및 논리 구성 요소



출처) 과학기술정보통신부, “제로트러스트 가이드라인 2.0”

• 제로트러스트 아키텍처 논리 구성 요소는 다음과 같음

- 정책결정지점(PDP): 정책 엔진(PE)과 정책 관리자(PA)로 구성된 요소로, 접근 주체의 리소스 접근 허용 여부를 최종 결정해 정책시행지점(PEP)에 전달하는 역할 수행
- 정책 엔진(PE): 기업망의 정책과 신뢰도 평가를 기반으로 리소스 접근을 최종 허가·거부·취소하며, 정책 관리자가 이를 실행
- 정책 관리자(PA): 정책 엔진과 함께 PDP를 구성해 PEP를 통해 세션의 통신 경로를 제어하며, 토큰 발급과 세션 허용·거부 결정을 수행하되 최종 판단은 정책 엔진에 의존
- 정책시행지점(PEP): 접근 주체와 리소스 간 연결을 중재·모니터링·종료하는 요소로, 정책 관리자와 통신하며 정책을 적용하고, 클라이언트 에이전트·게이트웨이·포탈 등 형태로 구현되어 리소스 앞의 문지기 역할 수행
- 정책정보지점(PIP): 정책 엔진에 제공할 정보를 생성·전달하는 요소로, 기업 내부 시스템뿐 아니라 외부 시스템도 포함될 수 있으며, 신뢰도 판단에 유용한 정보를 제공하는 모든 시스템 포함

■ 글로벌 국가(한국, 캐나다, 영국, 일본, 중국 등)들은 미국이 제로트러스트 관련 정책 발표를 시작하면서, 자국 환경을 고려한 제로트러스트 관련 문서를 발표하고 있음

- 각 국가는 「NIST SP 800-207」을 기반으로 자국 환경에 적합한 제로트러스트 개념을 정립하고, 이를 정부 차원의 정책 문서로 발표하여 확산을 추진함

<표 4> 주요국 제로트러스트 정책 현황

단계	설명
대한민국 	• 2023년, 과학기술정보통신부와 한국인터넷진흥원(KISA)은 국내 기관·기업이 제로트러스트 개념을 도입할 수 있도록 기본 원칙과 참조 모델을 제시한 「제로트러스트 가이드라인 1.0」 발표 • 2024년, 제로트러스트 도입·운영 단계에서 필요한 구체적 요구사항과 성숙도 평가 모델을 보완해 공공·민간 전반의 확산을 지원하는 「제로트러스트 가이드라인 2.0」 발표
캐나다 	• 2022년, 캐나다 정부는 제로트러스트 보안 프레임워크를 개발하기 위한 노력으로 「Zero Trust Security Model(ITSAP.10.008)」 발표
영국 	• 2021년, 영국의 국가사이버보안센터(NCSC)는 「Zero trust architecture design principles v1.0」을 발표하여 제로트러스트 아키텍처 설계 8원칙 제안
일본 	• 2020년, 일본 CIO는 「정부 시스템에서 제로트러스트 적용을 위한 사고 방식」을 발표하면서 제로트러스트 개념을 공식적으로 도입하기 시작하였고, 2021년, 디지털청에서 「제로트러스트 네트워크를 달성하기 위한 정부 직원의 계정과 자산 관리 지침」 발표 • 2022년, 디지털청에서 「제로트러스트 아키텍처 적용 정책」 발표 • 이후, 지속적으로 제로트러스트 정책 관련 문서를 발표하면서, 보다 정교한 접근 통제 체계를 도입하기 위한 기술적 기반을 마련하고 있는 것으로 확인
중국 	• 2019년, 중국산업정보통신부는 「사이버보안 산업 발전 촉진에 대한 지침」을 발표하면서 네트워크 보안 핵심 기술 중 하나로 제로트러스트 명시 • 2021년, 중국전자산업표준화기술협회는 중국 제로트러스트 표준(T/CESA 1165-2021)인 「제로트러스트 시스템 기술 사양」 초안 공개

출처) 주요국 자료 재구성

제3장 OT 특화 제로트러스트(OT ZT)의 필요성

3-1 OT 위협 사례

- ▶ OT 대상 사이버 위협은 물리적 피해와 사회적 혼란을 초래하는 고위험 사이버 위협임
- ▶ 보안 성숙도가 낮은 조직일수록 침해사고가 빈번하며, 망분리·세그멘테이션 미흡이 공격 확산의 주요 원인으로 작용함
- ▶ 국가 지원 해킹조직이 OT 인프라를 전략적으로 공격하며 사이버전 양상이 심화되고 있음

■ OT 보안 기업 Fortinet이 발표한 ‘2025 State of Operational Technology and Cybersecurity Report’에 따르면 전 세계 OT 조직의 절반이 사이버 공격을 경험

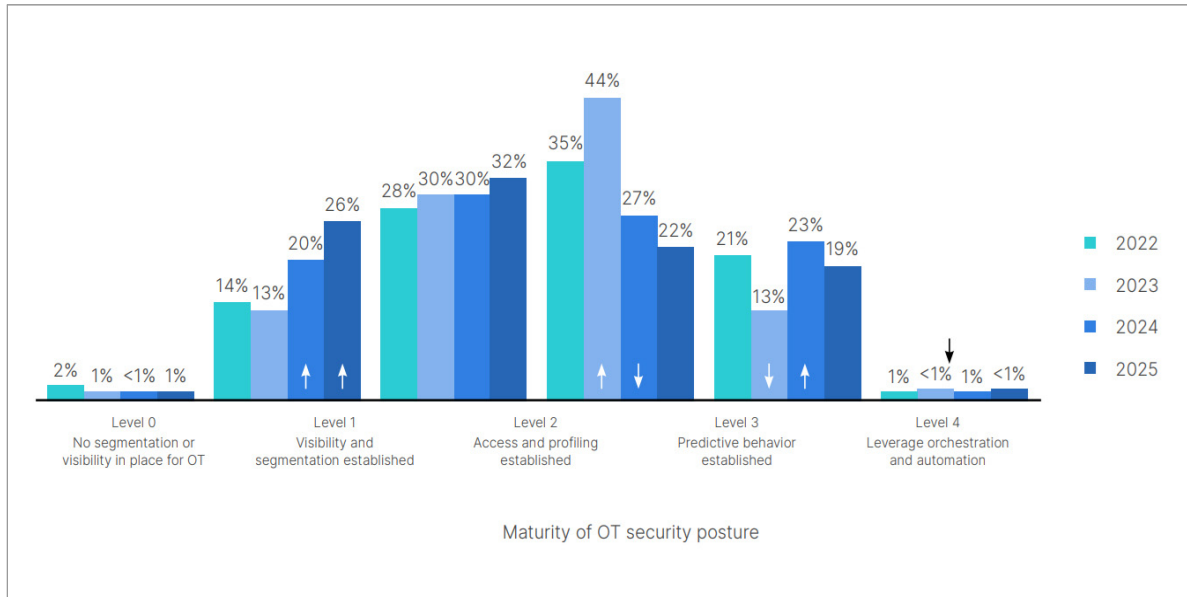
- IT 대상 침해사고가 주로 데이터 탈취나 서비스 지연에 그치는 것과 달리, OT를 대상으로 한 사이버 공격은 설비 오작동, 생산 중단, 정전, 장비 파손 등 물리적 피해로 직결되어 사회 전반에 훨씬 더 큰 피해를 초래함
- OT를 대상으로 수행되는 사이버 공격은 매년 증가하고 있으며 보안 성숙도 레벨 4에 해당하는 기업의 65%는 침해를 경험하지 않았다고 응답한 반면, 성숙도 레벨 0~2에 해당하는 기업은 46%만이 침해를 경험하지 않았다고 응답
 - 보안 성숙도가 높은 기업일수록 사이버 공격 피해가 상대적으로 적은 것으로 분석
 - 낮은 레벨의 조직은 피싱과 같은 기본적인 공격으로도 피해를 입었으며, 레벨 3과 레벨 4 조직은 랜섬웨어·멀웨어 등 고급 공격에 의한 피해 발생
 - 보안 성숙도는 Level 0~4까지 존재하며, 보안 수준이 낮은 조직은 APT(지능형 지속 위협)나 OT 전용 악성코드 같은 정교한 위협의 존재를 인지하지 못하는 경우 존재

<표 5> OT 보안 성숙도 설명

수준	설명
Level 0	• OT에 대한 세분화(segmentation)나 가시성이 전혀 없음
Level 1	• 가시성과 세분화가 구축됨
Level 2	• 접근제어와 프로파일링이 구축됨
Level 3	• 행위 기반 예측 기능이 구축됨
Level 4	• 오케스트레이션과 자동화를 활용함

출처) Fortinet, “2025 State of Operational Technology and Cybersecurity Report”

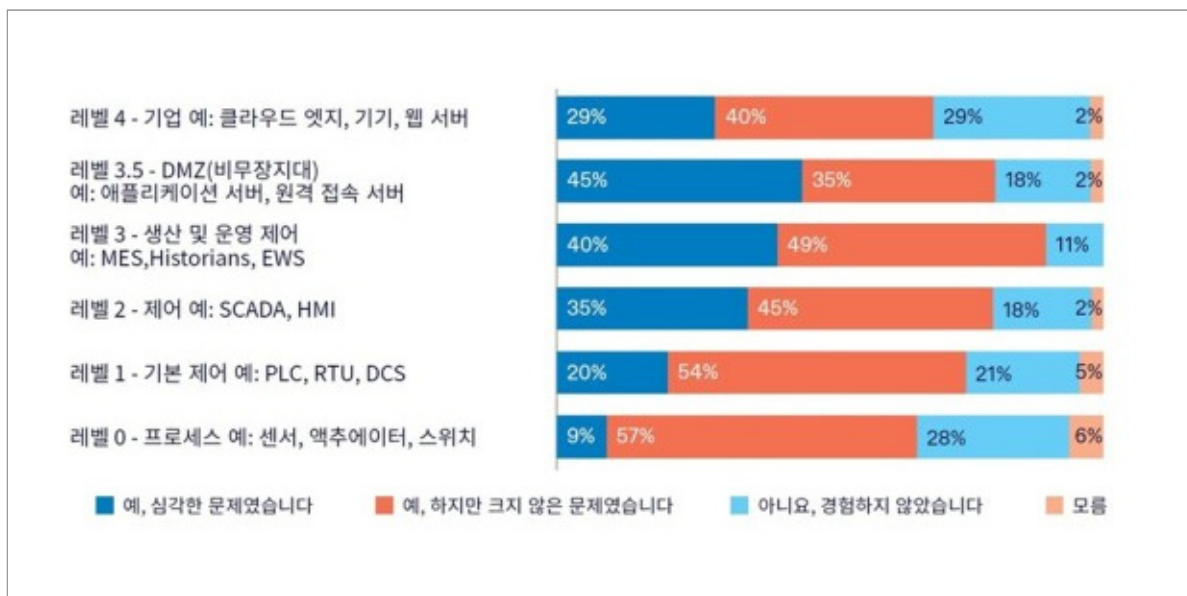
<그림 5> OT 보안 성숙도별 사이버 침해사고 비율



출처) Fortinet, “2025 State of Operational Technology and Cybersecurity Report”

- 또한 망분리와 네트워크 세그멘테이션이 제대로 구현·운영되지 않을 경우, IT 영역에서 발생한 침해가 통제 없이 OT 영역으로 확산되어 공격으로 이어짐
- 데이터넷 기사에서 인용한 OMDIA(옴디아) 자료에 따르면 OT 조직의 80%가 레벨 3.5(DMZ)에서 보안 사고 경험

<그림 6> OT 레벨별 사이버 침해사건 발생 비율



출처) 데이터넷, “[OT보안②] 사회 전체 피해 입히는 OT 타깃 공격”, 2024.11

■ 최근 OT 환경을 대상으로 한 랜섬웨어 공격이 급증하고 있으며, 이는 IT망 침해를 통해 OT 제어·운영 기능을 마비시키는 파급효과를 발생시킴

- Fortinet의 ‘2024 State of Operational Technology and Cybersecurity Report’에 따르면 사이버 공격을 받은 OT 조직의 절반이 랜섬웨어 및 와이퍼 공격으로 조사
 - 와이퍼 공격: 공격자가 대상 시스템의 파일·디스크·부트레코드(MBR/GPT 등)를 삭제하거나 손상시켜 데이터를 복구하기 어렵게 만들고, 시스템의 정상 부팅 및 운영을 불가능하게 만드는 파괴형 악성코드 공격
- OT 환경에서 발생한 침해 사례들은 대부분 내부 폐쇄망 침입을 위해 외부망에서부터 내부 OT망까지 치밀하게 준비된 APT 공격
 - 랜섬웨어는 망분리 및 네트워크 세그멘테이션 미흡을 틈타 OT 영역까지 확산
- IT망에 대한 랜섬웨어로도 OT 운영에 필요한 물류, 재고, 결제 등 핵심 정보 시스템이 중단되어 OT 시스템들의 운영에 차질이 발생함
 - 즉, OT 제어시스템이 정상이어도 운영 관리가 불가능해 생산 차질, 서비스 중단, 사회적 혼란으로 이어짐

<표 6> 연도별 OT 시스템 랜섬웨어 공격 사례

발생시기	사례명/대상	영향 및 피해내용
2019	Norsk Hydro	• 전 세계 공장 가동 차질 발생, OT·생산 라인 일시 중단. 피해액 수천만 달러 규모 • 전세계 알루미늄 가격 상승 (사건 전 대비 1.2%)
2020	Honda	• 전 세계 공장 11곳의 생산라인 관리 시스템 마비, 일본 공장에서는 완성차 출하가 일시 중단
2021	Colonial Pipeline	• 송유관 운영 중단, 미국 동부 연료 공급에 큰 차질. 몸값 약 440만 달러 지불 후 복구
2022	Delta Electronics	• 서버 1,500대와 컴퓨터 12,000대 암호화 및 주요 데이터 탈취, 1500만 달러를 요구
2023	Dole 식품회사	• 북미지역의 4개의 가공공장 시스템 중단, 식품 배송 중단으로 인한 2주간 배송 지연
2023	나고야항	• 나고야항 내 5개 컨테이너 터미널의 반입, 반출 작업 정지로 약 2일동안 물류 처리에 차질 발생
2024	VARTA 배터리 제조시설	• 배터리 생산 시설 5개 운영 중단으로 인한 피해 발생
2025	Data I/O	• 반도체 생산 장비 생산/출하 시스템 중단으로 인한 금전적 피해 발생

출처) 뉴스기사 재구성

- 최근 OT 대상 랜섬웨어 공격은 OT에 직접적으로 연결되어 있는 원격 접속 계정(RDP·VPN)을 탈취하여 외부에서 내부 OT망으로 접속하여 랜섬웨어 감염 시도
 - 설비 점검과 유지보수 편의를 이유로 외부 협력업체나 파트너사가 OT망에 원격 접속을 요청
 - OT 보안 전문업체 클라로티(Claroty)에 따르면, 응답자의 79%가 OT 네트워크에 팀뷰어(TeamViewer)·애니 데스크(AnyDesk) 등 원격 도구를 설치했으며, 이들 중 대부분은 지난 1년간 해당 앱을 통한 침해를 최소 한 차례 이상 경험한 것으로 조사⁶⁾
- 랜섬웨어는 피싱 이메일을 통해 악성 링크나 첨부파일을 열게 하여 사용자의 계정을 탈취하고, 확보한 권한을 바탕으로 내부망에 침투해 OT 시스템까지 확산을 시도

6) 보안뉴스, “OT 환경 노리는 랜섬웨어 공격이 증가하고 있는 가운데, CISO의 할 일은?”, 2024.10

■ OT 환경을 노린 사이버 공격은 물리적 피해와 경제적 손실을 넘어서 국가 기반시설 안정성 및 사회 전반에 큰 충격을 줄 수 있는 심각한 사이버보안 위험

- 원격 진단 등 OT가 IT 시스템과 연결되면서 공격 표면이 확대되고 있으며, 레거시 시스템의 취약점 발견 및 보안 패치 적용의 어려움으로 위험이 높아지고 있음. 특히 2010년 Stuxnet 사례와 같이 제로데이 취약점을 악용해 현장 장치를 직접적으로 공격하는 ICS 침투형 악성코드 등 더욱 정교한 공격 방식이 등장
- OT 시설을 직접 공격하여 정보 습득뿐만 아니라 전력망·원자력·수도·교통과 같은 국가 핵심 인프라를 마비시킴으로써 사실상 국가 안보를 겨냥한 사이버전 양상을 보임. 즉, OT 대상의 실제 공격이 발생할 경우 국가 기반시설과 사회 기능 전반에 심각한 피해로 이어질 수 있기 때문에 OT 보안 강화가 필수적임
 - 기존 사이버 공격은 회사 내 기밀 자료를 탈취하거나, 전산 시스템을 마비시키는 것이 목표였으나, 최근에는 OT에 대한 사이버 공격을 통하여 공정에 피해를 주거나 시설 자체를 파괴
 - 과거 큰 전쟁은 포격과 공습으로 시작됐지만 미래의 전쟁은 전력시스템 등 OT 기반 시스템 및 인프라를 마비시키는 사이버 공격부터 시작될 것으로 예상
- 대표적으로 Stuxnet은 원자력시설의 OT망에 침투해 PLC를 변조, 핵시설 원심분리기를 물리적으로 파괴함으로써 특정 국가의 핵 개발을 저지하고 OT 대상 사이버 공격이 국가 안보와 국제 정세에 직접적인 영향을 미칠 수 있음을 보여준 사례임

<표 7> 연도별 OT 시스템 대상 주요 사이버 공격 사례

발생시기	사례명/대상	영향 및 피해내용
2010	Stuxnet (이란 나탄즈 핵시설)	• USB 등 외부 매체 통해 폐쇄망 침투 → Siemens PLC 변조 • 원심분리기 물리적 파괴 → 핵개발 차질, 세계 최초 OT 특화 사이버무기 • 사이버 공격이 물리적 설비 파괴로 이어질 수 있음을 시사
2014	일본 후쿠이현 몬주 핵 발전소	• 몬주 핵 발전소 내 reactor 제어실 컴퓨터에서 악성코드 발견 (42,000개 이상의 문서 도난) • 작업자가 컴퓨터의 동영상 재생 프로그램 업데이트를 수행한 후 감염 • 망분리 환경에 대한 공급망 공격 및 SW 취약점 기반 공격 위험성 시사
2015	BlackEnergy 3.0 (우크라이나 전력망)	• 피싱 이메일 통한 악성 매크로 설치 → SCADA 시스템 접근 • 30만 가구 정전, 약 6시간 이상 전력 공급 중단 • 사회공학 기반 초기 침투가 실제 OT 제어시스템 임의 조작으로 이어질 수 있음을 보여주는 사례
2016	Industroyer / CrashOverride (우크라이나 전력망)	• 발전소에서 사용하는 작업 프로세스 오작동 유발 • 우크레네르고社 운영의 피브니치나(발전소) 전력망 중단 • OT 환경 프로토콜 취약점이 직접 악용된 사례로, OT 프로토콜 보안 필요성 시사
2019	인도 쿠단쿨람 원자력발전소 공격	• 원전 관리 연결망에 악성코드(Dtrack) 감염되어, 원전 1기 중단 • 내부 데이터 수집과 내부 확산 공격을 통해 원전 중요시스템 접근 시도 • IT망 침투 이후 장기적 정찰과 내부 확산을 통해 OT 파괴 시도로 이어질 가능성을 보여주는 사례

발생시기	사례명/대상	영향 및 피해내용
2021	Oldsmar 수도 시설 공격 (미국 플로리다)	- 원격 접속 소프트웨어 TeamViewer 계정 탈취 - 수산화나트륨(가성소다) 투입량 100배 증가 시도 → 직원이 즉시 발견해 피해 방지 - 원격접속 계정 탈취만으로 OT 환경에서의 물리적 피해가 발생할 수 있음을 시사
2023	국내 스마트팜 설비 원격 조작	- 취약한 비밀번호 설정을 활용하여 스마트팜 개폐기 시스템을 원격으로 임의 조작 - 곡물 투입 원격제어 설비시스템 해킹을 통한 임의 조작
2024	Volt Typhoon (미국 전력·수도 인프라 침투 시도)	'볼트 타이푼'(Volt Typhoon)으로 알려진 중국 해커단체가 최소 5년간 항공, 철도, 도로, 해상, 파이프라인, 상하수도 등 미국 주요 인프라를 운영하는 네트워크에 지속적으로 침투
2024	FrostyGoop (우크라이나 난방 인프라 공격)	모드버스(Modbus) 프로토콜을 악용해 600여 개 건물의 난방·온수 공급을 48시간 동안 중단시킨 첫 사례
2025	이란 국영 선박 해킹	- 선박에 적용된 소프트웨어 취약점을 기반으로 유조선 39척 및 화물선 25척의 중앙 통신 시스템 해킹 - 해킹으로 인해 선박 간 위치 공유 및 연락 불가로 항로이탈, 선박 간 충돌 발생 가능
2025	라이세바트넷 댐 해킹 (노르웨이)	해커의 공격으로 인해 수문이 임의 개방되어 4시간 동안 720만 리터의 수자원 방류

출처) 뉴스기사 재구성

■ OT를 겨냥하는 해킹 단체는 단순한 범죄조직을 넘어, 국가 차원의 지원을 받으며 상대 국가 핵심 인프라를 직접 타깃으로 삼는 사이버전 양상으로 발전

- OT를 겨냥한 해킹 단체는 조직적으로 움직이며 정교하고 치밀한 공격을 수행하여 상대 국가의 핵심 인프라를 정밀 타격함으로써 국가 간 사이버전이 현실화됨
- 러시아 총참모부 본부 정보국(GRU) 산하 Sandworm 그룹은 BlackEnergy, Industroyer, FrostyGoop 등을 통해 우크라이나 전력망·난방 인프라를 반복적으로 마비
- 우크라이나의 블랙잭(BlackJack)이라는 해커비스트 그룹은 가스, 수도 및 하수도 네트워크의 통신 시스템을 담당하는 모스크바 시립 조직인 모스콜렉터(Moskollektor)를 공격
- 미국과 이스라엘은 공동으로 Stuxnet을 개발해 이란 나탄즈 핵시설의 원심분리기를 물리적으로 파괴, 국가 핵개발을 저지
- 중국의 Volt Typhoon 그룹은 미국 전력·수도 OT망에 장기간 은밀히 침투하며, 위기 시 파괴를 노리는 전략적 활동 수행

3-2 OT 환경 특성 및 고유 취약점

- ▶ OT 환경에서의 보안은 망분리에 과도하게 의존해 내부 신뢰 구조와 외부 접점 관리의 사각지대 존재
- ▶ 가용성과 실시간성 우선 구조로 인해 취약점 패치, 암호화, 인증 적용이 제한되어 보안 대응의 어려움 존재
- ▶ OT 환경은 자산 가시성이 낮고, 위협 탐지 및 대응이 지연되는 구조적 한계를 가지며, 전용·비공개 프로토콜 사용으로 범용 IT 보안 솔루션의 적용이 제한됨

■ OT 사이버보안의 핵심은 '망분리'에 있었으나, 망분리 환경에서도 외부와의 연결을 100% 차단하는 것이 어려우며 망분리 기반 OT 망은 안전하다는 인식으로 인해 내부 가시성 확보 및 위협 대응에 소홀

- OT의 망분리로 인터넷과 단절된 환경, 외부와 차단되어 독립적으로 운영되는 시스템과 같이 외부와 연결이 되어 있지 않으면 안전하다는 인식이 현재까지 널리 퍼져 있음
- 하지만 OT를 대상으로 하는 사이버 공격 사례에서 알 수 있듯이 업무에 사용되는 USB, 외주 인력의 노트북, 유지보수를 위한 원격 접속 기능, 소프트웨어 업데이트를 위한 경로 등 물리적으로 분리되어 운영된 환경이라도 외부와의 접점이 존재
 - Stuxnet은 USB를 통한 물리적 침투를 수행하였고, 미국 올즈마 수도 시설 공격은 팀 뷰어를 통한 내부망 침투, 후쿠이현 몬주 핵 발전소 공격은 소프트웨어 업데이트를 통하여 내부망 침투 수행
 - 망분리 솔루션으로 외부 접근을 차단하더라도, 업데이트나 유지보수 등 운영 필요성 때문에 OT는 근본적으로 외부와의 접점에 대한 100% 차단 불가능
- OT 환경은 망분리에 의존해 내부망에 들어온 주체를 기본적으로 신뢰하는 구조를 가지기 때문에 내부자 위협에 대한 대응이 매우 미흡한 상황
 - 실제로 2024년 내부자 위협(의도하지 않은 사고 및 악의적 행위)은 전년대비 26%에서 50%로 두 배가량 증가하였고, 악의적 행위를 포함한 위협은 38%에서 63%로 급증

■ OT 시스템은 가용성과 실시간성을 최우선으로 하여 취약점 점검·보안 패치·보안 장비 설치조차 쉽게 적용하기 어렵고, 이로 인해 알려진 취약점이 장기간 방치되거나 대응이 지연되는 구조적 한계 존재

- 패치를 하는 과정에서도 업데이트로 인한 시스템 재부팅 시 설정 데이터가 초기화될 수 있고, 아주 작은 확률이라도 시스템 장애가 발생할 가능성이 존재하기 때문에 취약점 패치가 지연되거나 아예 방치되는 경우 존재
- Nmap, Nessus 등 일반적인 보안 스캐너 도구를 사용할 경우에 발생하는 패킷으로 인하여 OT 시스템이 오작동할 확률이 존재하기 때문에 보안 점검 도구 사용의 어려움 존재
- 침입방지시스템을 도입하더라도 아주 작은 확률로 정상 패킷을 차단할 경우에 OT 시스템에 심각한 장애를 유발할 수 있기 때문에 필터링 기능을 적극적으로 활용하지 못하고 침입탐지시스템 수준에 그치는 경우가 많음

- 또한 OT 시스템은 강한 실시간성 요구 조건 때문에, 인증 및 암호화 기술과 같이 가용성과 실시간성을 저해할 수 있는 보안 기술을 적용하기 어려움
 - IEC 61850-5(변전소 통신 네트워크 및 시스템 - 제5부 : 기능 및 장치 모델을 위한 통신 요구 사항)에 따르면 변전소 내 메시지 성능 요구사항에서 Trip 명령어는 3ms 이내에 전달되어야 한다고 규정되어 있음
 - 이처럼 강한 실시간성을 요구하는 환경에서 OT 시스템을 대상으로 인증, 암호 적용 등 전송 지연을 증가하는 보안 기술 적용이 매우 어려움

<표 8> 변전소 내 메시지 성능 요구사항

Transfer time class	Transfer time [ms]	Application examples: Transfer of
TT0	>1000	• Files, events, log contents
TT1	1000	• Events, alarms
TT2	500	• Operator commands
TT3	100	• Slow automatic interactions
TT4	20	• Fast automatic interactions
TT5	10	• Releases, Status changes
TT6	3	• Trips, Blockings

출처) IEC 61850-5, "Communication requirements for functions and device models"

■ OT 환경은 여전히 레거시 시스템에 크게 의존하고 있으며, 다양한 장비 및 복잡한 구성으로 인해 전체 시스템 및 네트워크 현황에 대한 가시성 부족

- OT 환경의 시스템들은 10~30년의 장기간 운용 주기를 가지며, 이로 인하여 OT 환경의 많은 시스템은 이미 수십년 전에 설계되어 보안이 전혀 고려되지 않은 레거시 시스템으로 구성
 - 과거에 생산되어 운영되는 OT 시스템은 기본적인 보안 기능조차 탑재되지 않아 외부 공격에 그대로 노출되는 경우가 많으며, 오래된 PLC, RTU, SCADA 장비는 암호화·인증 기능이 부족하여, 제어 명령 위변조나 불법 접근에 취약함
 - IT 시스템과 달리 OT 기기는 장기간 패치나 업데이트 없이 운용되며, 이로 인해 알려진 취약점이 장기간 방치되는 구조적 한계를 가짐
- OT 환경은 다양한 시스템과 복잡한 네트워크 구조로 인하여 자산현황 및 취약 지점을 명확히 파악하기 어렵고 보안 사고 발생 시에도 탐지·대응이 지연되는 구조적 한계 존재
 - OT 환경은 네트워크 가시성이 부족하여 공격자가 침투할 수 있는 네트워크 경로를 사전에 차단하기 힘들고, 제한된 모니터링 체계로 인하여 해킹이 발생해도 몇 주, 심지어 몇 달간 탐지되지 않아 장기간 내부 활동을 허용하는 위험 존재
 - 제조사별·세대별로 다양한 장비가 혼재되어 있어 보안 정책을 일관되게 적용하기 어렵고 일부 장비는 보안 기능이 거의 없거나 최신 기술을 지원하지 못하며, 이 같은 복잡성과 불균형은 결국 OT 환경의 사이버보안 공백으로 이어짐

- 전담 보안 인력이 부족하여 보안 전문 지식이 없는 운영 엔지니어가 보안을 겸임하는 경우가 많이 존재하여 사이버 위협 대응이 미흡하고 사고가 발생했을 때도 초기 대응이 지연되어 피해가 확산될 가능성이 큼

- 2023년 10월 26일 개최된 'OT & ICS 보안 인사이트 2023' 참가자 설문조사에서 응답자의 28.6%가 OT 환경의 가장 시급한 보안 과제로 '가시성 확보'를 꼽아 가장 높은 비중을 차지함⁷⁾

■ OT 환경은 제어 표준 및 비공개 전용 프로토콜을 사용하기 때문에 범용 IT 보안 솔루션을 그대로 적용하기 어려운 구조적 한계를 가짐

- OT 환경은 일반 IT 환경에서 사용되지 않는 독점 프로토콜을 기반으로 운영되기 때문에 전통적인 IT 보안 솔루션과의 호환성이 떨어짐
 - 레거시 시스템과 폐쇄적인 통신 프로토콜이 여전히 널리 사용되고 있어, 자산 검색·관리 기능을 갖춘 기존 IT 솔루션과 연동이 어렵고 그 결과 자산 식별이 불완전해 네트워크 가시성이 저하됨
- 방화벽, IDS/IPS, SIEM 등 범용 IT 보안 솔루션은 OT 환경에서 충분히 효과적으로 동작하지 못하며, OT 특화 프로토콜을 지원하고 DPI(Deep Packet Inspection) 기능을 내재한 전용 보안 솔루션이 필요함



7) 데이터넷, "[OT보안2023 설문] OT 조직 56% "OT 보안 계획 아직 없어", 2023.10

3-3 OT 환경에서의 제로트러스트 필요성

- ▶ 경계기반 보안만으로는 IT에서 OT로의 횡적 이동, 랜섬웨어, 국가기반시설 위협에 대응 한계가 뚜렷하며 OT 특화 제로트러스트가 필수 전략으로 부상
- ▶ IT 중심 제로트러스트는 OT의 지연·가용성 요구, 레거시 장비, 비표준 프로토콜 등 현실 제약으로 적용 한계가 뚜렷하므로 OT 환경에 특화된 제로트러스트 설계 및 단계적 도입 필요

■ Fortinet 보고서에 따르면, 전 세계 OT 조직 절반이 사이버 공격을 경험했으며 이는 경제적 손실을 넘어 국가 기반시설 안정성과 사회 전반에 중대한 위협이 되고 있음

- 최근 OT 공격으로 랜섬웨어가 대표적이며, IT망을 경유하거나 원격 유지보수·외부 협력사 연결 등 외부 접점을 통해 OT 영역으로 확산되는 특징을 보임
 - 공격자는 피싱 이메일을 통해 초기 침투에 성공하거나 계정을 탈취한 뒤, RDP·VPN 자격증명 및 원격 접속 도구를 악용해 IT망을 거쳐 폐쇄망 내부 OT 시스템까지 침투함
- 원자력시설의 원심분리기를 파괴한 Stuxnet, 미국 루즈벨트 댐 해킹 시도, 폴란드 트램 불법 제어 사례 등 OT망을 직접 공격하는 사례는 국가 차원의 안보 위협임을 보여줌
- 그러나 이러한 위협들은 경계 기반 보안 모델로 대응하기에는 한계를 보이고 있으므로 OT 제로트러스트 보안 모델의 도입이 핵심 전략으로 요구됨
 - 특히 OT와 IT가 밀접하게 연계되는 환경에서 제로트러스트는 공격자의 횡적 이동을 억제하고, 핵심 시설에 대한 접근을 정밀하게 제어하는 효과적인 방어체계로 작동할 수 있음
 - 그러나 그동안 연구되어 온 제로트러스트는 IT 환경에 맞추어서 발전되어왔으며, OT 환경에 적용하기 어렵다는 문제가 있음

■ 기존 IT 환경 기반 제로트러스트는 가용성·실시간성 중심의 OT 환경에 그대로 적용하기 어려운 구조적 한계를 가짐

- IT 제로트러스트는 인증·검증 강화로 인한 지연을 허용할 수 있지만, OT 보안은 가용성과 실시간성이 최우선이므로 동일한 절차를 적용할 경우 제어 명령 지연이나 운영 중단으로 이어질 수 있음
 - IT 환경에서는 사용자 인증·다단계 인증(MFA)·세션 토큰 갱신 과정에서 수 초 수준의 지연이 발생해도 업무 연속성에 큰 영향을 주지 않음
 - 그러나 OT망에서는 PLC, RTU, DCS 등 제어 장치 간 통신이 수 밀리초(ms) 단위 주기로 이루어지며, 지연이 발생하면 제어 신호 전달 실패, 공정 제어 오류, 안전 계전기 오동작으로 이어질 수 있음

- IT 제로트러스트는 정기 패치와 보안 기능 확장을 전제로 하지만, OT망은 레거시 시스템과 보안 기능이 부족한 장비가 많아 패치 지연·취약점 방치가 빈번하고, 이로 인해 IT 방식의 에이전트·암호화·중앙 인증 적용이 어렵다는 한계를 가짐
 - IT 환경은 정기적 패치·업데이트를 전제로 하지만, OT 장비는 10~30년의 운용 주기와 24시간 무중단 가동 특성 때문에 펌웨어 교체나 패치가 지연되거나 불가능한 경우가 많음
 - 또한, 일반적인 보안 스캐너(Nmap, Nessus 등)는 OT 장비 오작동을 유발할 수 있어 점검조차 제한적이어서 IT 제로트러스트가 가정하는 에이전트 설치·암호화 적용·중앙 인증이 현실적으로 어려울 수도 있음
- IT 환경은 계층적 구조보다 단일 네트워크 기반 접근제어에 익숙하지만, OT 환경은 Purdue 모델과 같은 계층적 구조에 따라 자산·데이터 흐름이 달라지므로, 동일한 보안 통제를 일괄적으로 적용하기 곤란함
 - IT 환경은 단일 네트워크 또는 클라우드 중심으로 접근제어가 가능하나, OT는 Purdue 모델 기반 계층 구조에 따라 보안 요구가 크게 달라짐
- IT 제로트러스트는 중앙 집중적 로깅과 분석 도구를 가정하지만, OT망은 독점 프로토콜과 낮은 호환성 때문에 기존 IT 솔루션으로는 가시성이 부족하며, 내부자 공격에 대한 대비가 미흡할 수밖에 없음
 - IT 제로트러스트는 표준 프로토콜 기반 중앙 로그 관리·SIEM 분석을 전제로 하지만, OT 환경은 Modbus·DNP3·Profinet 등 산업용 독점 프로토콜을 사용하여 기존 IT 솔루션과 호환성이 낮음

<표 9> IT 제로트러스트와 OT 환경에서의 제약사항 비교

구분	IT 제로트러스트에서의 가정	OT 환경의 제약·한계
목표/우선 순위	• 보안·기밀성 중심, 일정 수준의 지연·단기 서비스 중단은 허용 가능	• 가용성·실시간성 최우선, 제어 신호 지연 시 생산 중단·안전사고로 직결
패치·업데이트	• 정기적 패치·보안 기능 확장을 전제로 안정적 운영 가능	• 레거시 시스템으로 인해 패치 지연·적용 제한, 취약점 방치 위험
네트워크 구조	• 단일 네트워크·클라우드 중심 접근제어 구조	• Purdue 모델 기반 계층 구조로 레벨별 자산 특성에 따라 보안 요구 상이
로그·가시성	• 표준 프로토콜 기반 중앙 로그·SIEM 분석 가정	• 산업용 프로토콜 특성으로 기존 IT 보안 솔루션과 호환성이 낮아, 네트워크·자산 가시성 확보 제한

출처) 저자 재구성

■ OT의 특성을 고려하여, OT 환경에 특화된 맞춤형 제로트러스트 모델 필요

- OT 보안은 가용성과 실시간성을 최우선으로 고려해야 하므로, 보안 통제가 시스템 성능 저하나 지연을 유발하지 않도록 설계되어야 함
 - 초기에는 보호 대상 범위를 작게 설정하고, 운영 흐름을 가시화하여 지연 요인을 파악하고 안정적인 통제 지점을 확보해야 함
 - 아키텍처 설계 시 에이전트 적용 가능 구간과 네트워크 기반 제어를 병행하여 불필요한 성능 저하를 줄이고, 기본 차단 원칙과 보안 절차를 함께 적용해 연속성을 보장해야 함

- OT망은 장기간 운용되는 레거시 시스템과 보안 기능이 부족한 장비들로 인해 취약점이 방치되기 쉬우므로, 네트워크 세그멘테이션·OT 특화 보안 솔루션을 활용한 통제가 필요함
 - 패치·보안 기능 구현이 어려운 장비는 자산 식별 및 메타데이터 관리를 통해 네트워크 차원에서 보호할 수 있는 방안을 모색해야 함
 - 패치 지연에 따른 취약점은 지속적 모니터링·문맥 기반 평가·단방향 게이트웨이 등을 통한 다층 방어로 보완해야 함
- OT 환경에서는 Purdue 모델과 같은 계층적 구조를 고려한 제로트러스트 설계가 필요하며, 해당 모델에서 각 레벨의 특성과 제약에 따라 정책 집행 방식을 다르게 하고 제로트러스트 구성 요소의 배치 지점을 고려해야 함
 - 상위 계층(레벨 3~5)은 주로 이더넷 기반 환경으로, 일반 OS에서 동작하는 서버·워크스테이션·애플리케이션이 포함되므로 보안 에이전트 설치가 가능하고, 사용자·프로세스 단위의 세밀한 정책 통제가 가능함
 - 반면 하위 계층(레벨 0~1)은 시리얼 기반 통신과 전용 펌웨어 장비(PLC, RTU, 센서 등)가 많아 에이전트 설치가 어렵고, 네트워크 세그멘테이션·화이트리스트 기반 접근제어·산업용 방화벽 등 네트워크 차원의 보안이 필요함
- 접근 및 행위 로그를 체계적으로 관리하고 가시성을 향상시켜 내부자 공격에 대한 대비가 필수적임
 - OT 네트워크는 독점 프로토콜 사용으로 인해 기존 IT 보안 솔루션과 호환성이 낮으므로, OT 전용 프로토콜 센서·DPI 등 OT 특화 기술을 활용해 가시성을 확보해야 함
 - OT 네트워크는 트래픽 패턴이 단순한 경우가 많아 정상 기준선을 설정하기 용이하며, 이를 기반으로 이상 행위를 조기에 탐지해야 함
 - 이러한 모니터링은 단순한 오탐을 줄이고 대응 속도를 높일 뿐만 아니라, 환경 변화에 맞춰 기준선을 주기적으로 갱신하는 체계를 마련하여 내부자 공격과 같은 은밀한 위협에도 선제적으로 대응할 수 있어야 함
 - 따라서 제로트러스트 보안 모델을 적용해 사용자의 신원·행위·접근 패턴을 지속적으로 검증하고, 최소 권한 원칙을 유지하는 정책을 통해 내부자 위협을 사전에 식별하여 횡적 이동을 차단해야 함



제4장 국내외 OT 특화 제로트러스트 정책 동향 및 적용 사례

4-1 해외 동향

- ▶ 미국 원자력 시설 특화 제로트러스트 정책, DoD의 실증을 통한 OT 특화 제로트러스트 전략, CSA 중요기반 시설 제로트러스트 가이드라인 등은 국내 OT 제로트러스트 로드맵 수립 등에 활용 가능
- ▶ 일본, 싱가포르 등은 OT 규제·가이드 강화로 보안성 향상을 추진 중이며, 국내도 이에 맞춰 OT 보안 기준·거버넌스·보고 체계·공급망 보안을 우선 고도화 한 후, 단계적인 OT-제로트러스트 전략 수립 필요

■ (미국) 2022년, 미국 원자력규제위원회(Nuclear Regulatory Commission, NRC)는 FFR(Future Focused Research) 프로그램의 일환으로 원자력시설 제로트러스트 아키텍처 적용 방안 연구 수행

- SMR 및 차세대 원자로에 새로운 디지털 기술이 적극 도입되면서 기존 보안 아키텍처로는 위협에 대응하기 어려운 점을 계기로 제로트러스트 아키텍처 도입 방안에 대한 연구 시작
- 해당 연구는 크게 3가지 업무를 중심으로 연구를 수행하였으며, 각 업무 수행 결과는 기술보고서(Technical Letter Report, TLS) 형태로 2022년~2025년 사이에 걸쳐 발표되었음

<표 10> NRC의 제로트러스트 관련 기술보고서

발간시기	업무	제목
2022.11	Task1	Zero Trust for Operational Technology Literature Review
2023.11	Task2	Zero Trust Architectures for Operational Technology at Nuclear Facilities
2025.02	Task3	Implementing Zero Trust for Operational Technology at Nuclear Facilities

출처) 저자 재구성

- NRC는 원자력 OT 환경에서 사고·공격 시 직접적으로 SSEP⁸⁾기능에 영향을 미치는 요소를 고려하여 제로트러스트 핵심 요소를 3가지(Device, Network, User) 선정

8) SSEP(Safety, Security, and Emergency Preparedness): 원자력시설에서 안전, 보안, 비상대응 역량을 통합적으로 관리·평가하기 요소

<표 11> NRC의 원자력시설 제로트러스트 핵심 요소

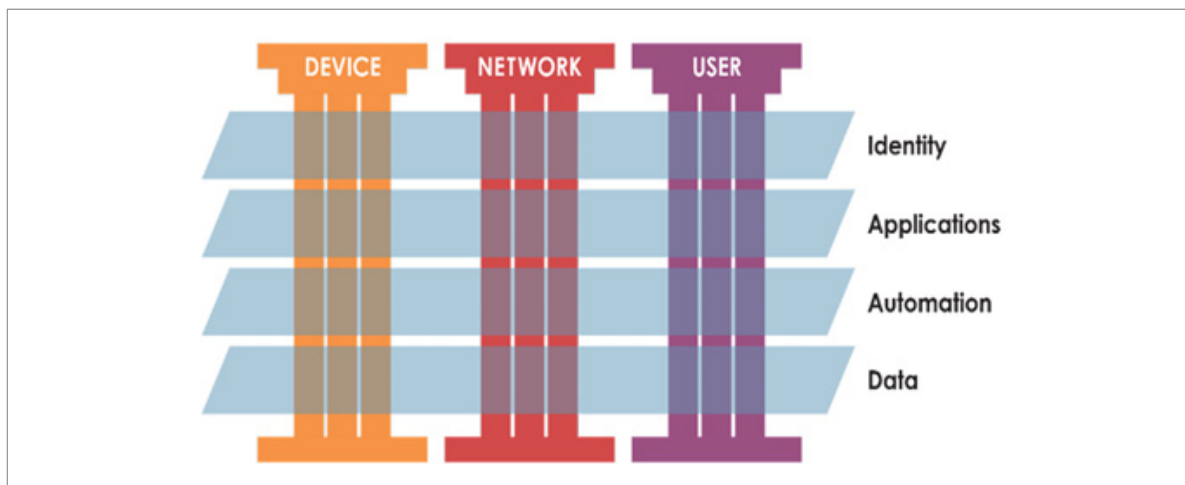
핵심 요소	설명
기기 (Device)	- 기기 정의는 네트워크 연결 가능한 하드웨어 자산으로 정의(CISA 기준) - 원자력 발전소(NPP)에서는 SSEP 기능 수행 또는 관련 장치가 필수 식별 대상 - 자동화 장치처럼 '사용자 역할'을 수행하는 디바이스도 포함하며, 원격 기기(드론)도 고려 대상
사용자 (User)	- 사용자 정의는 인간 + 비인간 엔티티(NIST SP 800-207 기준) - 모든 사용자는 식별·인증 필수, 그리고 역할·데이터·애플리케이션과 연계됨 - NPP 통제구역 내 장치와 연관된 사용자만 제로트러스트 검증 대상 - 원격 사용자도 포함 가능
네트워크 (Network)	- 네트워크도 ID·애플리케이션·데이터·기능을 보유한 엔티티로 간주 - 물리적 접근 자체도 네트워크의 일부로 포함됨 - 자동화를 통해 통신 트래픽을 인간 개입 최소화 상태에서 재구성 가능

- 반면, 독립적으로 SSEP 기능을 수행하지 않고 항상 핵심 요소와 연계되어 작동하는 교차 요소로 4가지 (Identity, Application, Automation, Data) 선정

<표 12> NRC의 원자력시설 제로트러스트 교차 요소

교차요소	설명
Identity (신원)	인증 및 권한 부여 기반 모든 기기, 사용자, 네트워크는 검증 가능한 신원을 가져야 함
Application (애플리케이션)	사용자가 사용하는 소프트웨어로, 최소 권한 설정 필요 (공격 표면 최소화)
Automation (자동화)	동적 정책 업데이트 및 실행을 가능하게 하는 핵심 기술 (예: 안전, 보안, 비상 대응 지원)
Data (데이터)	사용자와 장치 간 네트워크를 통해 전송, 상황 인식 및 신뢰 알고리즘 분석에 사용됨

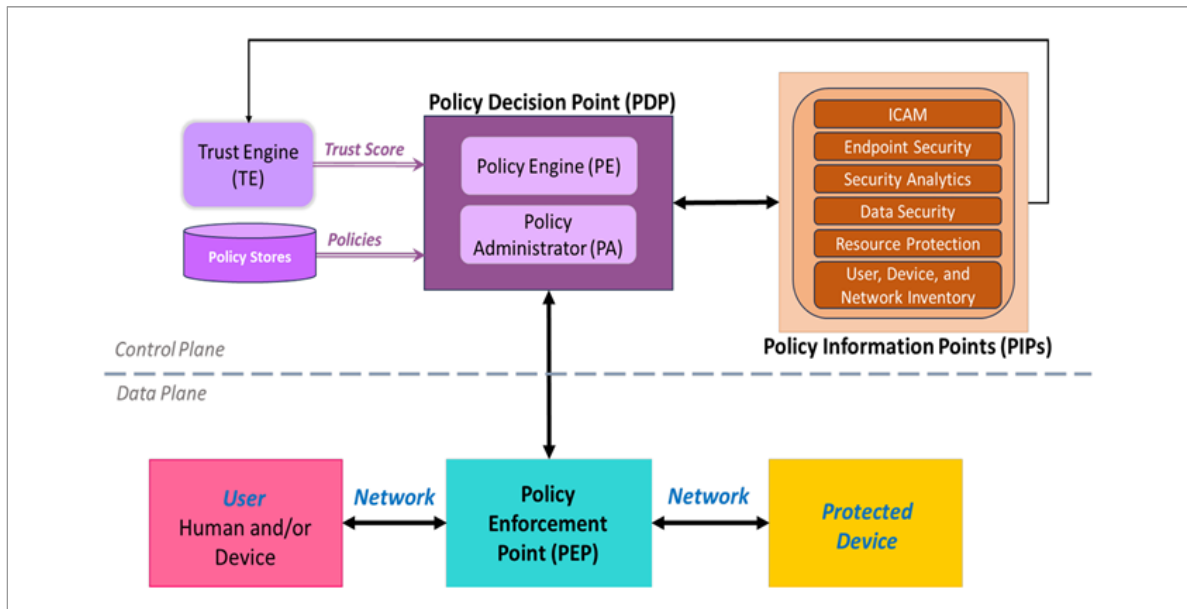
<그림 7> NRC의 원자력시설 제로트러스트 핵심 요소 및 교차 요소



출처) U.S.NRC, "Implementing Zero Trust for Operational Technology"

- NRC는 원자력시설 OT 환경에서의 제로트러스트 핵심 요소 3가지와 NIST SP 800-207에서 제공하는 논리적 제로트러스트 아키텍처의 데이터/제어 평면과 대응시킴
 - NRC의 제로트러스트 아키텍처는 일반적인 제로트러스트 아키텍처와 유사하게 정책결정지점(PDP), 정책 엔진(PE), 정책 관리자(PA), 신뢰도 엔진, 정책 저장소, 정책정보지점(PIP), 정책시행지점(PEP)으로 구성됨
 - 특히, NRC에서는 접근 주체에 대한 신뢰도를 판단할 수 있도록 정보를 제공하는 PIP에 대해 원자력시설에서 얻을 수 있는 정책정보지점에 대해 제시함

<그림 8> NRC의 원자력시설 논리적 제로트러스트 아키텍처



출처) U.S.NRC, "Implementing Zero Trust for Operational Technology"

<표 13> NRC의 원자력시설 환경에서의 PIP 요소

PIP 요소	설명
ICAM	• 사용자 계정, 신원 정보를 생성 및 저장하며, 관리하는 역할을 수행함 • 여기에는 단순한 사용자 신원 관리뿐 아니라 접근 및 자격증명 관리가 포함되며, 연합 신원(federated identity)도 이 범주에 속함 • 즉, 계정 생성부터 자격증명 유지·관리, 신원 연계까지 신원 및 권한 관련 전 과정을 포괄하는 범주
엔드포인트 보안	• 엔드포인트를 공격으로부터 보호하고 관리되는 장치와 관리되지 않는 장치 모두가 네트워크에 미치는 영향을 차단하는 보안 기술과 솔루션을 의미 • 여기에는 호스트 기반 방화벽, 악성코드 스캐닝 및 방어 장치, 취약점 및 위협 완화 기법, 그리고 호스트 침입 방지 활동이 모두 포함됨
보안 분석	• 원자력시설에 필요한 모든 위협 인텔리전스 피드와 트래픽/활동 모니터링을 수집하는 기능 • 통신 경로와 네트워크를 포함해 자산의 현재 상태에 대한 보안 및 행위 분석을 모으고 자산 및 네트워크를 지속적으로 모니터링하여 위협이나 악의적 활동에 능동적으로 대응할 수 있도록 함
데이터 보안	• 원자력시설에서 보호된 자산에 안전하게 접근하기 위한 정책을 포함하며, 데이터가 저장되거나 전송되는 과정에서 이를 보호하는 수단까지 아우름 • 즉, 안전한 데이터 접근과 보호를 위한 정책적·기술적 장치 전반을 의미

PIP 요소	설명
리소스 보호	- 다른 범주에 속하지는 않지만 자원을 보호하기 위한 요소들이 해당 - 자원 앞단에서 프록시 역할을 하거나, 모니터링과 제어를 통해 자원을 보호하는 구성 요소들이 이 범주에 포함
기기/사용자/ 네트워크 인벤토리	- 이 항목은 NRC 직원이 추가한 것으로, 해당 장치가 ①안전을 직접 보장하는 장치(Safety), ②안전에 중요한 영향을 미치는 장치(Important-to-Safety), ③보안을 담당하는 장치(Security) 중 어느 범주에 속하는지 구분하도록 요구 - 보호 대상 장치가 맡은 안전·보안 기능을 알아야 취약점 관리나 모니터링 같은 보호 조치를 제대로 적용할 수 있으며, 이는 결국 “무엇을 보유하고 있는가”라는 질문에 대한 답이 됨

출처) U.S.NRC, “Implementing Zero Trust for Operational Technology”

• NRC는 RG 5.71에서 제시한 아키텍처를 기반으로 논리적 제로트러스트 아키텍처 구성 요소를 어디에, 어떻게 배치할지에 대해 2가지 모델 제안

- 중앙 집중식 배치 모델: 제로트러스트 아키텍처 구성 요소는 전용 보안 레벨인 Level ZT에 통합되어 있으며, PEP만 각 보안 레벨에 분산 배치
- 중앙 집중식 배치 모델은 Level ZT의 PDP가 모든 보안 정책 결정을 맡기 때문에 정책 생성·유지가 단순하며, 전체 아키텍처에 대해 일관된 보안 태세를 유지할 수 있다는 장점이 있지만 중앙 PDP가 고장나면 전체 시스템에 영향을 미친다는 단점도 존재
- 연합형 배치 모델: 각 보안 레벨(0~4)에 독립적인 제로트러스트 아키텍처 구성 요소를 보유하며, 해당 레벨의 PDP가 정책 결정을 내리면 PEP가 로컬 수준에서 접근제어
- 연합형 배치 모델은 각 레벨별로 로컬 정책과 데이터에 기반한 통제가 가능하여 레벨별 독립성과 자율성이 커진다는 장점이 있지만, 전체적인 아키텍처의 상황 인식을 확보하기 위한 별도의 고려가 필요하다는 점을 단점으로 보고 있음

<그림 9> NRC의 원자력시설 접근제어 배치 모델



출처) U.S.NRC, “Implementing Zero Trust for Operational Technology”

- NRC는 제로트러스트 아키텍처의 기능에 부합하도록 선정된 NIST SP 800-53 보안 통제를 기반으로, 사이버보안 계획(Cyber Security Plan, CSP)에 반영 가능한 추가 통제 항목 제시
 - 많은 원자력 시설은 자체 조정된 CSP를 운용하며, 이러한 CSP는 「원자력 발전소를 위한 사이버 보안 프로그램 (NRC RG-5.71)」, 「원자력 발전소 사이버 보안 계획(NEI 08-09)」, 「원자력 발전소 - 계측, 제어 및 전력 시스템 - 보안 제어(IEC 63096)」 등의 지침을 기반으로 구축되어 있음
 - 그러나 현행 CSP는 NIST SP 800-53의 모든 보안 통제를 포함하지 않으며, 제로트러스트 아키텍처 구현에 요구되는 일부 항목(지속적 검증·마이크로세그멘테이션·정교한 맥락 기반 접근제어 등)이 지침상에 충분히 반영되어 있지 않음
 - 이에, NRC는 제로트러스트에 부합하는 보안 통제항목을 도출하고자 하였고, NIST SP 800-53 내 총 13개의 영역에서 73개의 보안 통제항목을 도출
- 제로트러스트 환경에서 리소스 접근을 시도하는 모든 주체(인간·비인간 포함)에 대해 위험 수준을 신뢰 점수로 수치화하도록 함
 - 신뢰 점수는 과거 행위, 스캔 결과, 장치 상태 등 다양한 속성과 메트릭을 분석하는 신뢰 알고리즘을 통해 산출되며, 신뢰 엔진이 이를 생성·관리함
 - 점수가 높을수록 위험은 감소하고 보안 유지 가능성은 높아지며, 본질적으로 동적 특성을 가져 지속적 검증과 정책 갱신을 가능하게 함

<그림 10> NRC 신뢰 점수 계산 방법 예시



출처) NRC 자료 저자 재구성

- NRC는 제로트러스트 관점에서 접근 주체의 신뢰도를 평가하기 위해 신뢰 속성 제시
 - 신뢰 속성은 사용자·비인간 사용자·자원·네트워크 4가지 범주로 구분되며, 인증 강도·취약점 상태·기기 보안 수준·자원 중요도·트래픽 이상 행위 등 각 속성을 평가하여 접근 주체의 신뢰도를 판단하는 기준으로 활용됨

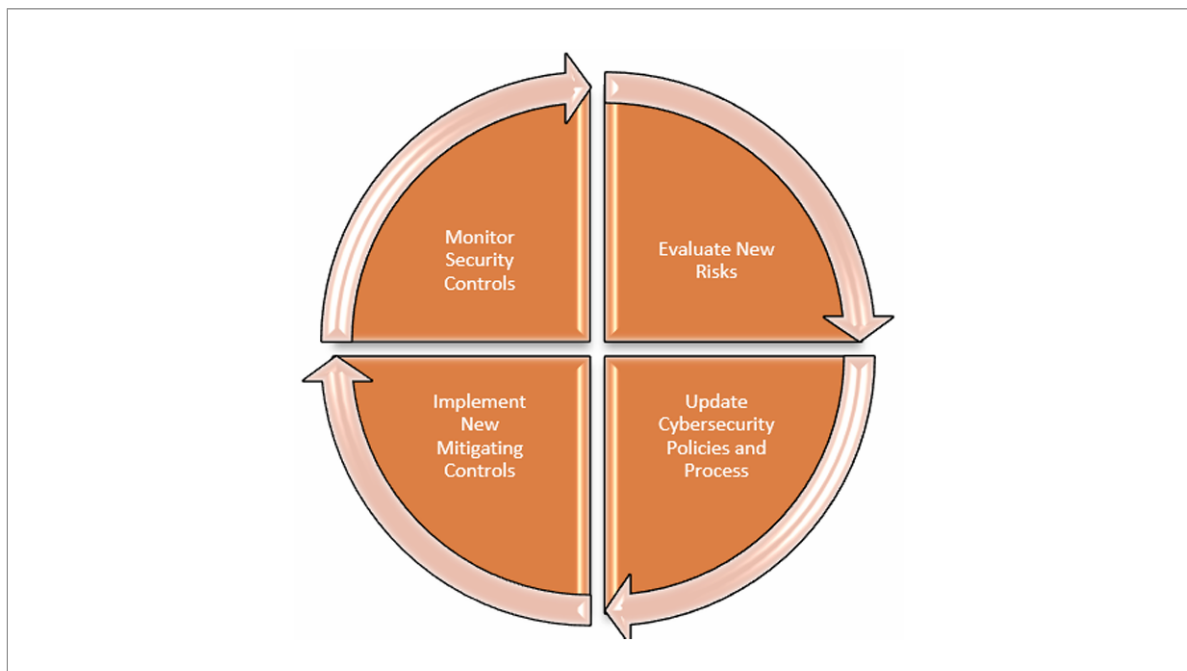
<그림 11> NRC의 신뢰 속성



출처) NRC 자료 저자 재구성

- 신기술 도입 시 위험 평가, 정책·절차 개선, 완화 통제 구현, 통제 모니터링으로 4단계 위험 관리 사이클을 제시하고 있음

<그림 12> NRC의 신기술 도입을 위한 위험 관리 사이클



출처) U.S.NRC, "Implementing Zero Trust for Operational Technology"

- 신기술 도입 시에는 기기·네트워크·운영 절차의 취약점과 위험을 분석하고, 수집 데이터의 기밀성·무결성·접근 제어 확보, 악성코드 삽입 여부 점검 등 새로운 보안 위험 평가가 필요함

- 신기술 사용 과정에서 정책적 모호성 보완, 공급망 신뢰성 검증 강화 및 해당 기술이 제로트러스트 아키텍처 어느 영역에 반영될지를 결정하는 등 보안 정책 및 절차 개선 요구
- 도입된 보안 대책의 효과성을 점검하고 무선 통신 모니터링 장치 스캔 등, IIoT, 정교화된 점검을 통해 보안 통제 모니터링을 지속 수행해야 함

<표 14> NRC의 신기술 도입을 위한 위험 관리 단계

단계	설명
Step 1. 새로운 사이버보안 위험 평가	• 신기술(드론, AI 등) 도입 시 발생할 수 있는 장비·네트워크·운영 절차의 취약점 평가 • 드론 수집 데이터는 기밀성·무결성·접근통제 보장이 필요 • 신규 장비의 접근·구성 관리 취약점, 악성코드 삽입 가능성 점검 • 새로운 기술이 기존 방어 아키텍처에 미치는 영향 및 ZT 요소(예: 무선/원격 운영) 적용 필요성 검토
Step 2. 보안 정책 및 절차 업데이트	• 신기술 활용 시 기존 정책·절차의 모호성을 보완 • 공급망 위험 관리 강화: 공급업체의 보안성 검증, 장비의 보안 설계 여부 확인 • ZTA 적용 시 어떤 기능을 활용할지 정의(예: 무선 침입 탐지 시스템 → PEP·PIP 기능 수행) • 하드웨어·소프트웨어·펌웨어 공급망 검증 및 보안성 확보 필요
Step 3. 새로운 완화 통제 적용	• 파악된 취약점에 대해 데이터·소프트웨어·펌웨어·통신(유·무선) 보호 대책 적용 • 계정·접근·권한 관리와 암호화 적용, 패치 적용 및 별도 샌드박스에서 사전 테스트 수행 • 장치 자체 보안이 미흡할 경우, 플랜트 환경* 내 보안 기능으로 보완 가능 * 신기술 장치 자체에서 보안 통제를 구현하지 못할 경우, 발전소 내부 네트워크나 보안 인프라 차원에서 대신 보안 기능을 적용한다는 의미
Step 4. 보안 통제 모니터링	• 새로 적용한 보안 통제의 효과성을 지속 모니터링해 신규 위험 식별 • IIoT·무선 통신 등 특화된 트래픽 감시 장비, 신기술 장치 스캐닝 도구 활용

출처) U.S.NRC, "Implementing Zero Trust for Operational Technology"

- 본 문서는 SSEP 기능과 원자력시설의 특수한 OT 환경을 고려하여 기기·네트워크·사용자를 중심으로 한 제로트러스트 아키텍처 적용 방안을 제시한 것이 특징이나, 다음과 같은 한계점 존재
 - 문서에서는 기기·네트워크·사용자 활동에 대한 가시성 확보의 중요성을 언급하고 있으나, 이 외에 가시성에 대한 언급을 하고 있지 않으며 이를 구현하기 위한 구체적 기술 방안이나 모니터링 체계 또한 제시되지 않음
 - 이러한 한계로 인해 지속적 검증 기반의 제로트러스트 운영체계를 구현하기 어렵고, 특히 본 문서가 원자력시설의 특수한 OT 환경을 전제로 하고 있어 일반적인 산업 OT 환경에서는 참고는 가능하나 직접적인 적용에는 어려움이 따를 수 있음

■ (미국) 2023년, NIST에서 발표한 「Guide to Operational Technology Security(SP 800-82 r3)」는 OT 환경 보안을 위한 대표적 국제 가이드라인으로, 본 문서에서는 네트워크 보안 영역에서 세분화·격리, 중앙 로그 관리, 모니터링 등의 방법을 설명하면서 제로트러스트 아키텍처 명시

- IT와 OT 장비를 관리 권한·신뢰 수준·기능 중요도·데이터 흐름에 따라 구분·세분화하며, Purdue 모델·ISA-95·IIoT 아키텍처 등을 활용할 수 있음
 - DMZ를 통한 구간 경계 설정이 중요하며, 방화벽·라우터·데이터 다이오드로 구간 간 통신을 제한하고 인가된 흐름만 허용해야 함

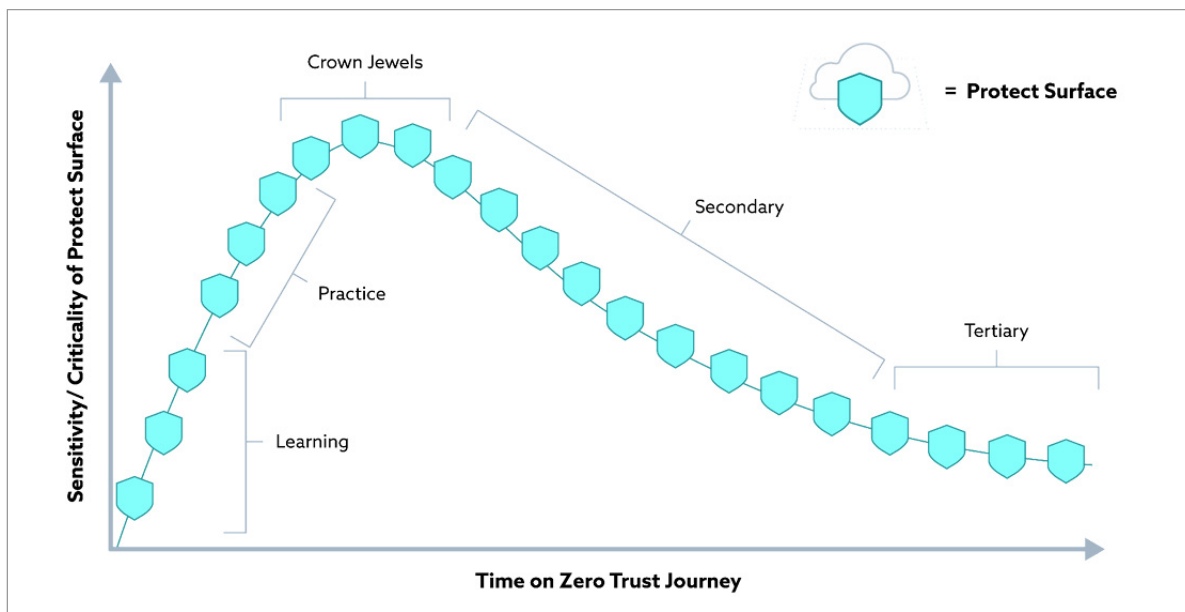
- 라우터, 게이트웨이, 방화벽, 서버 등 주요 네트워크·컴퓨팅 장비는 반드시 이벤트 로그를 기록하고, 이를 중앙 관리 플랫폼에 집약하여 모니터링·경보·사고 대응에 활용해야 함
 - 보존 기간과 저장 용량 정책을 사전에 수립하는 것이 필요
- IDS/IPS, SIEM 등을 통해 트래픽을 분석하고 이상 행위 탐지
 - OT 트래픽은 IT보다 결정적인 요소를 가지고 있어 정상 상태를 기준으로 삼아 공격 여부를 구분해야 하며, 암호화된 통신에 따른 모니터링 한계도 고려해야 함.
 - IDS/IPS는 OT 프로토콜(Modbus, DNP3 등)에 특화된 서명 활용이 가능하나, IPS 자동 대응은 OT 가용성에 영향을 줄 수 있어 DMZ 등 상위 계층에 배치하는 것이 권장됨
- 기존 경계 보안으로는 구간 내 횡적 이동을 막기 어렵기 때문에, 접근 통제를 자원 가까이에 배치하고 지속적으로 검증하는 ZTA 개념을 적용할 필요가 있음을 제시
 - 다만 PLC, 컨트롤러 등 일부 OT 장비는 ZTA 구현을 지원하지 못할 수 있어, Purdue 모델 3~5계층 등 상위 계층 장비에 우선 적용하는 방식이 현실적임
 - 성능 저하·지연·단일 장애 지점 문제를 고려해 최적화가 필요하고 OT 환경의 공유 계정 사용은 ZTA 도입의 또 다른 과제가 될 수 있음

■ (미국) 2024년, CSA(Cloud Security Alliance)는 중요기반시설 및 ISC 환경에서 제로트러스트 적용을 위한 지침을 포함하는 「Zero Trust Guidance for Critical Infrastructure」 문서 발간

- 본 문서는 주요 인프라(Critical Infrastructure, CI)에서 직면할 수 있는 위협을 설명하면서, 이러한 위협에 대해 대응하기 위한 목적으로 제로트러스트 전략 제시
 - 미국 CISA에서 정의한 CI 분야로는 화학(농업, 소비재 등), 상업 시설, 댐, 군/국방 방위산업, 정보기술, 원자로 원자재/폐기물 등이 있음
 - 대부분의 CI는 레거시 시스템 및 특수한 프로토콜에 의존하고 패치 및 업그레이드가 용이하지 않은 폐쇄형 시스템을 갖추고 있기 때문에 위협에 노출되면 파급력이 강함
 - 또한, IT와 OT랑 융합되면서 무선통신, SaaS(클라우드), 인터넷 연결 등이 증가하여 하나의 취약점이 여러 분야의 장애를 초래할 위험이 있음
 - 이에, 제로트러스트 아키텍처를 구현하여 시스템 보안 향상, 제도·법률·컴플라이언스 요건 충족, 사이버 공격 방어를 동시에 달성하는 것을 목표로 가짐
- 본 문서는 IT 환경과 OT 환경 간의 근본적 차이를 체계적으로 비교하고 OT 환경이 지니는 고유한 특수성을 제시함으로써, 기존 IT 중심의 제로트러스트 모델을 그대로 OT/ICS 환경에 적용하기에는 한계가 있음을 시사함
 - IT는 기밀성·무결성·가용성을 균형 있게 고려해 설계되는 반면, OT는 기밀성과 무결성보다 지속적이고 안전한 가용성 유지를 최우선으로 하는 특징을 가짐
 - IT 환경에서는 유지보수나 시스템 변경에 비교적 유연하지만, OT 환경은 짧은 가동 중단조차 허용되지 않으며 새로운 기술이나 도구를 도입할 때도 안전성과 운영 영향에 대한 충분한 검토가 필요

- 또한 OT는 복잡하고 고비용의 시스템으로 구성되어 있어 위협에 즉각 대응하기 어렵고, 독점 프로토콜 사용으로 인해 정기적 업데이트가 힘들
- OT는 시스템 장애가 안전, 건강, 환경, 국가 안보에까지 영향을 미칠 수 있는 위험성을 내포하며, 국가·경제 전반에 걸친 광범위한 규모의 영향을 발생시킬 수 있음
- OT는 공공과 민간 소유권이 혼재된 경우가 많아, 시스템 업데이트와 같은 보안 결정 과정에서 이해관계 조정이 추가적으로 필요하다는 특수성을 지님
- 이러한 IT와 OT의 차이점 및 OT 환경의 특성으로 인해 OT 환경에 특화된 제로트러스트 아키텍처가 요구되는 상황임
- 본 문서는 제로트러스트 도입을 위한 점진적 접근 방식으로 기어가기(Crawl)-걸기(Walk)-달리기(Run) 접근법을 권장
 - Crawl 단계에서는 비교적 위험도가 낮고 영향 범위가 제한적인 보호 표면을 대상으로 제로트러스트 적용 시도(테스트)
 - Walk 단계는 Crawl 단계에서의 경험을 토대로 점차 보호 표면 적용 범위를 확장함
 - Run 단계에서는 핵심 자산에 제로트러스트를 도입하고, 이를 조직 전반의 보안·운영 프로세스에 완전히 통합하여 성숙한 제로트러스트 체계를 구축하도록 함
 - 이를 통해 조직은 정책 수립, 기술 배치, 운영 절차 등에서 시행착오를 최소화하며 학습 효과를 축적할 수 있고, 단계적 접근으로 초기 과도한 투자나 운영 충격을 피하면서도 안정적으로 보안 수준을 고도화할 수 있음

<그림 13> CSA의 OT 환경 제로트러스트 접근법



출처) CSA, "Zero Trust Guidance for Critical Infrastructure"

- 본 문서는 OT·ICS 환경에서의 제로트러스트 적용 5단계 프로세스(① 보호 표면 정의 → ② 운영 흐름 매핑 → ③ 제로트러스트 아키텍처 구축 → ④ 제로트러스트 정책 수립 → ⑤ 지속 모니터링 및 유지관리)를 제시

- 이 5단계는 IT 환경에 적용되던 일반적인 제로트러스트 프레임워크를 그대로 모방한 것이 아니라, OT/ICS 환경의 특수성(안전·가용성 우선, 장기 운용, 레거시 장비 존재)을 반영해 재구성
- 따라서 단순한 보안 통제가 아니라 운영 안정성과 보안 통합을 동시에 달성하기 위한 절차로 설계
- 또한 각 단계는 ISA/IEC 62443의 Zone-Conduit 모델과 제로트러스트 원칙을 바탕으로 만들어졌으며, 위협 기반 사고 관점에서 어떤 자산이 보호 대상인가(Protect Surface) → 어떤 방식으로 연결·작동하는가(Flow Mapping) → 이를 어떻게 제어·검증할 것인가(Architecture·Policy) → 어떻게 지속적으로 보장할 것인가(Monitoring)”라는 논리적 흐름을 따른 구조임

<표 15> OT·ICS 환경 제로트러스트 적용 5단계 프로세스

단계 번호	프로세스 이름	설명
1단계	보호 표면 정의	• 중요 자산(데이터·애플리케이션·장비·서비스, DAAS) 식별 및 우선 순위화
2단계	운영 흐름 매핑	• OT 자산 간 제어·프로세스 흐름을 파악하여 위협 확산 경로 차단
3단계	ZTA 구축	• Purdue/Zone-Conduit 모델 기반 세분화 및 경계 설정
4단계	ZT 정책 수립	• 최소 권한, 지속적 검증, 상황 기반 인증
5단계	지속 모니터링 및 유지관리	• SIEM·IDS/IPS 활용, 운영 안정성과 보안 균형 유지

출처) CSA, “Zero Trust Guidance for Critical Infrastructure”

- CSA는 자신들이 제시한 5단계 프로세스를 통해 SANS⁹⁾의 주요 통제 항목을 강화할 수 있다고 언급

<표 16> SANS의 OT/ICS 주요 통제항목 및 CSA 중요기반시설 ZT와의 관계

주요 통제항목	설명	CSA 중요기반시설 ZT와의 관계
ICS 사고 대응	• 시스템이 계속 작동하면서 공격의 영향을 최소화하고 운영에 미치는 영향을 줄이기 위한 조치 우선	• 5단계(지속 모니터링 및 유지관리)의 일부
방어 가능한 아키텍처	• 시스템 설계·구현을 통해 위험을 줄이고 보안 담당자의 활동을 지원하는 구조	• 구현 절차의 전 단계에 걸쳐 이루어짐
가시성과 모니터링	• 상호연동된 ICS 구성 요소 간 상호작용을 이해하기 위한 네트워크·로그 모니터링 및 분석 필수	• 5단계(지속 모니터링 및 유지관리)와 일치
안전한 원격 접속	• MFA 적용을 원칙으로 하되 불가한 환경에는 점프호스트 등 통제 지점 마련, 상황별 원격 연결 차단 가능 구조 설계	• 구현 절차의 전 단계에 걸쳐 이루어짐
위험 기반 취약점 관리	• 모든 취약점을 동일 처리하지 않고, 조직에 실질적 위험을 초래하는 취약점에 우선 대응	• 2단계를 통해 핵심 데이터 흐름에 대한 포괄적인 이해를 제공함으로써 이를 강화

- (미국) 미 공군 Spangdahlem 기지(독일)는 DoD 내 최초로 ‘Project BlastWave’ 제로트러스트 기반 사이버 보안 솔루션을 상수·하수 처리시설(독일 Spangdahlem 공군기지)에 도입하여 산업제어시스템의 영구적 취약점을 보호하는 시범사업을 개시함

- BlastWave의 솔루션은 2017년에 제로트러스트 원칙을 기반으로 ICS와 중요기반시설을 보호하기 위해 개발되었음

9) SANS Institute: 1989년에 설립된 세계 최대 규모의 보안 교육 및 연구 기관으로, 매년 수만 명의 보안 전문가를 대상으로 교육 과정을 운영하고 있으며 보안 통제 가이드라인(SANS Top 20, 현 CIS Controls)을 개발하여 업계에서 기준으로 활용하고 있음

- ‘Project BlastWave’는 DoD 제로트러스트 관리사무소에서 약 26만 7천 달러를 지원받아 추진되었으며, 2023년 12월 19일부로 시범사업이 시작되었음
- ‘Project BlastWave’는 BlastWave 기업을 중심으로 설립된 OTZTA(Operational Technology Zero Trust Alliance)의 주요 실증 과제로, OT 네트워크 내 제로트러스트 보안 모델을 실제 산업제어 시스템에 적용·검증한 사례임

<표 17> OTZTA 소속 기업 및 역할

기업명	역할
BlastWave	• 제로트러스트 기반 OT 보안 솔루션 제공, 실세계에 기반한 OT 제로트러스트 기능 구현
Nozomi Networks	• OT/IoT 보안에서 글로벌 리더, 네트워크·엔드포인트 가시성, 위협 탐지 및 AI 기반 분석 제공
Booz Allen Hamilton	• 미 정부를 대상으로 제로 트러스트 추진, OT 영역까지 확장된 전략 제공
DarkTrace	• AI 기반 사이버보안 솔루션 제공, 이상 징후 탐지에 강점
SwimLane	• 보안 자동화 플랫폼 제공, 저코드 방식으로 지속적 컴플라이언스 및 대응 가능
CloudBees	• DevOps 및 소프트웨어 전달 보안 지원, OT 보안 개발 프로세스 연계
Fend	• 데이터 다이오드를 통해 OT 시스템을 물리적으로 보호하며 연속적인 데이터 모니터링 가능

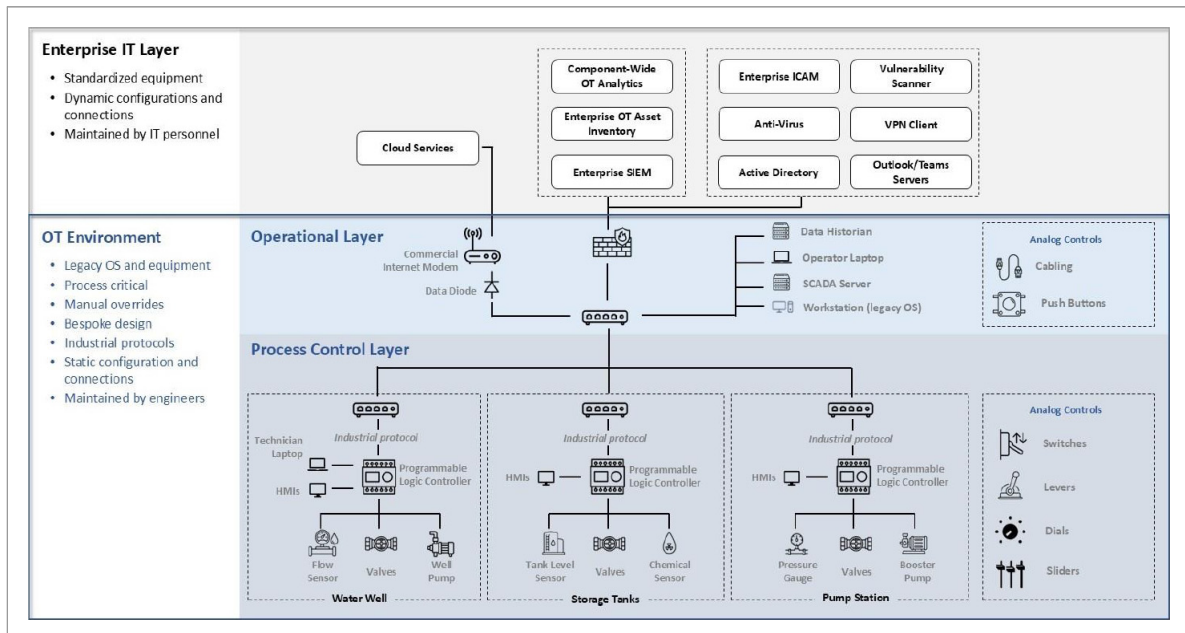
출처) OTZTA

- ICS 내부의 취약점을 외부에 보이지 않게 은폐하고, 마이크로세그멘테이션과 AI 기반 탐지·차단을 통해 공격 확산을 방지하는 제로트러스트 보안 기능 제공
- 본 시범사업은 군 기지의 물·하수 처리시설을 시작으로, 향후 DoD 전반의 중요 인프라 및 산업제어시스템 보호 체계로 확산될 전망임

■ (미국) 미 국방부(DoD)는 OT 환경의 고가용성·레거시 장비 사용·다양한 산업용 프로토콜 등의 특성, 물리적 보안 고려사항 등을 반영한 OT 제로트러스트 전략에 대해 2025년 11월 말 발표하고 구체적인 단계별 활동 정의

- 기존 IT 전략과 유사한 틀을 유지하되 단계별 활동 수를 152개(목표 91개, 고급 61개)에서 105개(목표 84개, 고급 21개)로 축소하여 현실성을 높임
- Purdue 모델, IEC 62443, UFC 4-010-06 등에서 활용하는 전통적인 5계층 구조 대신 추상화된 2계층(운영 계층, 프로세스 제어 계층)으로 구분
 - OT 환경에서의 ZT 활동은 고수준의 요구사항에 따라 더 유연하고 동적으로 만들기 위함
 - 엔터프라이즈 IT 계층은 조직의 일반적인 정보 기술 환경을 의미하며, 이메일 서버, 조달 및 자산 관리 서비스, 신원 인증 서비스 등을 포함
 - 운영 계층은 개념적으로 감시 계층(응용 서비스, 제어 센터 워크스테이션, HMI 등) 및 자동화 계층(컨트롤러, 무선 게이트웨이 등)의 도구를 포함(Purdue 모델의 4, 5계층)
 - 프로세스 제어 계층은 센서, 액추에이터, 모터 및 기타 기계 장비의 로컬 작동을 가능하게 하는 현장 제어장치 및 시스템으로 구성(Purdue 모델의 0~3 계층)

<그림 14> 일반적인 음용수 시스템을 위한 엔터프라이즈 IT 및 OT 환경의 구분



출처) DoD, "Executive Summary: Zero Trust for Operational Technology"

- OT 환경이 본질적으로 디지털 환경과 물리적 환경을 통합하는 특성을 가짐에 따라 본 문서는 제로트러스트를 위한 물리적 고려사항 및 보안통제 제시

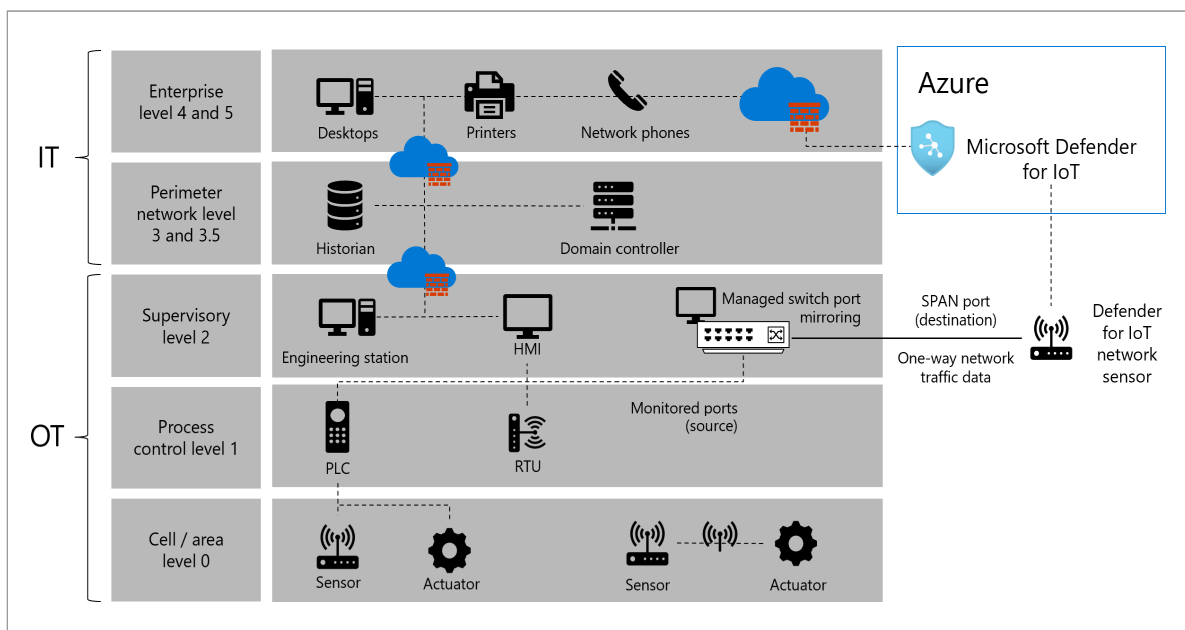
- IT 환경에서 MFA와 유사한 생체 인식 접근 제어(지문 스캐너, 얼굴 인식 등) 설치, 역할 기반 물리적 접근, IT 환경에서의 방화벽과 유사하게 주변 울타리 및 방벽 설치 등
- 물리적 보안 통제는 디지털 보안 조치를 대체하는 개념이 아닌 OT ZT를 위한 보완적 요소이며, 효과적인 제로트러스트 구현을 가능하게 하여 OT 환경에서의 복원력을 강화할 수 있음

■ (미국) Microsoft는 OT 네트워크에 제로트러스트 원칙을 적용하기 위해 명시적 확인·최소 권한·침해 가정의 3대 원칙을 기반으로, 점프 호스트·네트워크 세분화·상태 기반 접근제어 등을 활용한 현실적 수정 방안을 제안함

- Microsoft는 OT 네트워크에서의 고유한 위험 및 과제 4가지를 선정
 - ① 독점 프로토콜·노후화 장비·제한된 처리능력으로 보안 적용 제약
 - ② 안전·가용성 우선 설계로 정기 점검·패치가 제한적
 - ③ 외부 계약자 원격 접속 등으로 공격 노출 증가
 - ④ 클라우드·IIoT 확산으로 에어갭 모델 붕괴 및 공격 표면 확대
- Microsoft는 위와 같은 OT 네트워크 특성을 반영한 제로트러스트 원칙을 제시함
 - 네트워크-기기 간 모든 연결을 식별·관리해 숨은 종속성과 예기치 않은 중단을 방지하고, 필요한 경우 점프 호스트를 통해 원격 세션을 제한적으로 허용하며 MFA·권한 관리 등 강력한 인증을 적용
 - 기기·세그먼트 간 통신을 암호화·보호하고, 네트워크를 분할해 측면 이동을 차단하며, ICS 전반의 통신도 소규모 영역으로 나누어 모니터링과 유지관리의 용이성 확보

- 기기의 위치·상태·행동 데이터를 기반으로 접근을 제한하고, 최신 상태 유지·분석·자동화된 대응을 통해 보안을 강화
- 승인된 기기·트래픽 기준을 지속적으로 점검하며, 인력·기기·시스템의 변화에 맞춰 세그먼트와 접근 정책을 주기적으로 조정
- Microsoft는 자사의 솔루션인 Defender for IoT를 활용하여 OT 네트워크에 제로트러스트 원칙을 적용하기 위한 구체적 정책과 실행 방안을 제시하고 있음
 - OT 제로트러스트는 상시 모니터링과 가시성 확보가 핵심적이며, IoT 기기의 증가로 인해 이 모니터링 범위가 OT 외부까지 확대됨
 - Defender for IoT는 OT-IoT 전반의 트래픽과 기기 상태를 통합적으로 모니터링하여 OT 제로트러스트에서 요구되는 지속적인 검증을 가능하게 함
- <그림 15>는 Microsoft Defender for IoT의 Purdue 모델 기반 배치 구조를 보여줌
 - Microsoft Defender for IoT은 OT 네트워크의 스위치에서 SPAN¹⁰⁾/TAP¹¹⁾ 기반 패시브 트래픽 수집 센서를 사용하여 Level 1~3 구간의 통신을 모니터링함
 - 수집된 트래픽은 Azure로 전송되어 클라우드 기반 분석 엔진에서 ICS 프로토콜 해석, 자산 식별, 이상 행위 탐지를 수행
 - 센서는 OT 네트워크 내부에 위치하지만, 보안 분석·경보 처리·대시보드 관리는 Azure Defender for IoT에서 중앙화된 방식으로 운영됨
 - 이러한 구조는 IT-OT 전반의 트래픽을 통합 모니터링하며, 생산 설비의 제어 명령 흐름을 방해하지 않는 비침투적 (passive) 보안 감시 모델을 제공함

<그림 15> Microsoft 사의 Microsoft Defender for IoT 배치 방안



출처) Microsoft, "Defender for IoT and your network architecture"

10) Switch Port Analyzer의 약어로, 스위치에서 특정 포트의 트래픽을 복제(mirroring)해서 다른 포트로 보내는 기능

11) Terminal Access Point의 약어로, 물리적으로 케이블 사이에 설치해 트래픽을 하드웨어 수준에서 복제하는 장치

■ (EU) NIS2 Directive는 유럽연합(EU)이 제정한 법적 구속력을 갖는 사이버보안 지침(Directive)으로, 중요 기반시설 및 산업 인프라 전반에 대한 보안 의무를 강화하고 OT/ICS 영역까지 규제 범위를 확장하고 있음

- 2016년 NIS Directive(Directive 2016/1148)을 채택하여 유럽 전역의 네트워크 및 정보시스템의 사이버 보호 기반 마련
- 클라우드 서비스, 원격근무, IoT·OT 환경 등 증가하는 사이버 위협 대응을 위해 2022년 12월 NIS2 Directive(Directive 2022/2555)로 개정됨
- 이는 에너지·운송·금융·보건·디지털 인프라 등 산업 전반을 포괄하며 중형·대형 민간·공공기업 및 공급망 등으로 적용 범위를 확대함
- 체계화된 모니터링 및 거버넌스를 포함하여 ICS/OT를 포함한 중요 기반시설의 보안 의무를 강화하고 있음
 - 사고 발생 시 24시간 내 초기 보고, 72시간 내 상세 보고, 1개월 내 최종 보고 등 보고 체계 강화
 - 경영진의 사이버보안 전략, 위험관리 책임 및 교육·훈련을 의무화하여 보안을 조직 전체의 문제로 인식하도록 함
 - 불이행 시 과징금 부과를 통해 이행 강제성 강조
- 2024년 10월부터 EU 국가 대상 적용이 시작되어 2025년 8월 기준, EU 27개 회원국 중 14개국에서 법제화가 완료되었으며, 계속해서 법제화 진행 중
- EU는 법적 구속력이 강한 규제를 기반으로 OT 보안을 강화하고 있으며, EU 내 사업을 하는 제3국 기업도 NIS2 준수를 요구받을 수 있음

■ (일본) 경제산업성(METI)은 「공장 시스템을 위한 사이버/물리 보안 가이드라인」을 발표하며, 공장 내 다양한 기기가 네트워크에 연결되는 사례가 증가함에 따라 기업이 마련해야 할 보안 대책 제시

- 일본은 디지털청과 경제산업성을 중심으로 스마트팩토리·스마트시티를 아우르는 보안 정책을 마련함
 - 해당 가이드라인은 공급망 전반의 보안 위험, OT-IT 융합 과정에서의 네트워크 확장·외부 연결 증가, 클라우드·IoT 기기 활용에 따른 새로운 위협을 체계적으로 정의하고, 제로트러스트 개념 도입 가능성까지 포함하여 보안 관리 체계를 구체적으로 제시
 - 특히, 공급업체에도 보안 표준(SEMI E187¹²⁾ 등)을 요구하여 산업 전반에 보안 요건을 확산하는 정책을 추진 중이며, 이는 개별 기업 차원을 넘어 국가 차원에서 산업 경쟁력과 보안의 균형을 도모하는 전략으로 평가됨

■ (싱가포르) 싱가포르 사이버보안청(CSA)은 「Operational Technology Cybersecurity Masterplan 2024」를 발표하며, 국가 차원에서 OT 환경 전반의 보안 수준 제고를 추진하고 있음

- 이 계획은 CII(Critical Information Infrastructure)를 넘어 비핵심 OT 영역까지 포함해, 산업 전반의 보안 성숙도를 높이는 것을 목표로 함

12) 반도체 등 제조 장비에 적용되는 국제 보안 표준

- 주요 전략에는 Secure-by-Deployment 원칙(설계→배치→운영 전 과정 보안 내재화), 인력 양성 및 전문 교육 체계 확립, 위협 정보 공유 및 사고 보고 체계 강화, 공급망 및 비핵심 OT 부문까지 보안 확대 등이 포함되며, 이를 통해 OT 환경을 IT와 동등한 수준에서 다루면서도 OT 특수성을 반영한 보안 관리 체계를 마련함
- 특히, 공급업체에도 보안 표준(SEMI E187 등)을 요구하여 산업 전반에 보안 요건을 확산하는 정책을 추진 중이며, 이는 개별 기업 차원을 넘어 국가 차원에서 산업 경쟁력과 보안의 균형을 도모하는 전략으로 평가됨
- 또한 「Cybersecurity Code of Practice For Critical Information Infrastructure - Second Edition Revision One(이하, CCoP 2.0)」을 통해 OT를 포함한 기반시설 운영자들에게 최소 보안 요건을 의무화하여, 제도적 강제력을 기반으로 한 체계적인 보안 거버넌스를 확립

4-2 국내 동향

- ▶ 국내 OT 보안은 국가 차원의 공통 지침과 산업별 특화 가이드라인을 통해 최소 보안수준과 현장 적용성을 확보하고 있음
- ▶ 제로트러스트는 금융·클라우드 등 IT 환경을 중심으로 연구 및 실증사업 진행 중
- ▶ 그러나 OT 환경에 특화된 제로트러스트 적용과 검증은 아직 이루어지지 못하고 있으며, 이에 따라 OT 환경 대상의 제로트러스트 실증 사업 추진이 필요함

■ 국내 OT 보안은 국가 차원에서 제정된 공통 지침을 기반으로 운영되고 있으며, 주요 기반시설 전반에 최소한의 보안 기준을 제시하고 각 기관의 관리·운영 체계에 직접 반영되고 있음

- 국가정보원의 「국가정보보안기본지침」 제53조의2(제어시스템 보안)는 각급 기관이 OT 및 ICS를 비롯한 국가 중요 제어시스템을 운영할 때 백신설치, 보안패치 및 침해사고 대응방안 수립 등 보안대책을 마련하고 업무망과 분리하거나 안전한 연동수단을 적용하도록 규정
 - 기타 제어시스템 보안과 관련한 사항은 국가정보원장이 배포한 「국가·공공기관 제어시스템 보안가이드라인」 준수 강제
- 과학기술정보통신부의 「주요정보통신기반시설 취약점 분석·평가 기준」은 주요정보통신기반시설 내 정보시스템 및 제어시스템에 대한 400여 개의 보안 점검 항목을 제시하며 각 보안 점검 항목의 만족 요구
 - 관리적 분야, 물리적 분야, 기술적 분야(유닉스, 윈도우, 보안 장비, 네트워크 장비, 제어시스템, PC, 데이터베이스, 이동통신, 웹) 별 취약점 분석·평가 기준 제시
 - 계정 관리, 패치 적용, 로그 관리, 접근통제 등 세부 점검 항목을 통해 기반시설 운영기관이 보안수준을 객관적으로 평가하고 취약점 개선을 체계적으로 수행할 수 있도록 함

- 한국정보통신기술협회(TTA)의 「산업제어시스템 보안 요구사항(TTAK.KO-12.0307)」은 산업제어시스템 내 계층별 기술적·관리적 보안 요구사항을 정의하여 산업 전반에서 공통적으로 적용되는 보안 표준 제공
 - 산업제어시스템 내 현장장치 계층, 제어 계층, 운영 계층에 대한 보안 감사, 식별·인증, 접근 통제, 전송/저장 데이터 보호, 보안 기능 관리, 상태 관리 등 종합적인 보안 요구사항 제시

<표 18> 산업제어시스템 보안 요구사항(TTAK.KO-12.0307) 구성

구분	문서명	요약
제1부	개념 및 참조모델	산업제어시스템 내 각 계층에 적용되는 보안요구사항을 정의하기 위해서 필요한 보안개념 및 보안참조모델 제시
제2부	현장장치 계층	현장장치 계층에 속하는 구성 요소들을 안전하게 관리 및 운영하는데 필요한 보안요구사항을 정의
제3부	제어 계층	제어 계층에 속하는 구성 요소들을 안전하게 관리 및 운영하는데 필요한 보안요구사항을 정의
제4부	운영 계층	운영 계층에 속하는 구성 요소들을 안전하게 관리 및 운영하는데 필요한 보안요구사항을 정의

출처) TTA, “산업제어시스템 보안 요구사항(TTAK.KO-12.0307)”

■ 국내 OT 환경은 산업별 고유한 운영 특성과 위협 요인을 고려하여 마련된 특화 보안 지침을 기반으로 운영되고 있으며, 이를 통해 각 분야의 핵심 인프라가 직면한 보안 요구사항을 충족하고 있음

- (신재생) 국가정보원의 「국가·공공기관 신재생에너지 보안가이드라인 및 체크리스트」는 신재생에너지 발전 및 운영 설비의 특수성을 반영하여 사이버보안 위협 대응 방안을 제시하며, 인터넷망과 분리되지 않은 환경에서 적용 가능한 실질적 보안 대책 제시
- (원자력) 한국원자력통제기술원(KINAC)의 「RS-015(원자력시설의 컴퓨터 및 정보시스템 보안)」는 원자력시설의 정보시스템 및 제어시스템을 전자적 침해행위로부터 보호하기 위한 보안 심사·검사 및 이행 기준을 제시
- (해양선박) 한국선급(KR)의 「해상 사이버보안 시스템 지침(2024)」은 선박 및 항만 IT/OT 시스템의 보안수준을 평가하고 관리하는 체계를 제시하며, 선박 운영과 안전 확보를 위한 단계별 대응방안 제시
- (전력망) 한국정보통신기술협회(TTA)의 「스마트그리드 보안 요구사항(TTAK.KO-12.0182/R1)」은 지능형 전력망 전 영역의 보안 기준을 정의하여 안정성과 복원력 확보 방안 제시
- (제조) 한국인터넷진흥원(KISA)의 「스마트공장 사이버보안 가이드」는 ICT와 제조설비가 융합된 스마트 공장의 특성을 고려하여 6개 영역의 보안 요구사항과 세부 점검항목을 제시하며, 현장에서 활용 가능한 체크리스트 제공
- (교통) 한국인터넷진흥원(KISA)의 「스마트교통 사이버보안 가이드」는 차량·인프라·네트워크가 실시간 연결되는 스마트교통의 특성을 고려하여, 서비스 구성 요소별 보안 요구사항과 대응방안을 제시하며, 현장에서 활용 가능한 점검 체크리스트 제공
- (에너지) 한국인터넷진흥원(KISA)의 「스마트에너지 사이버보안 가이드」는 AMI, ESS, EMS, EV 충전 시스템, 셀프주유기·충전기, 덕내 기기 등 주요 구성 요소를 대상으로 보안 요구사항과 대응방안 제시

<표 19> 국내 산업별 OT 보안 지침 및 가이드라인

산업분류	보안 지침	발간/개정일	주요 내용
신재생	국가·공공기관 신재생에너지 보안가이드라인 및 체크리스트	2025년 3월	- 태양광, 풍력, 연료전지 등 보안에 취약한 신재생 에너지 발전설비를 대상으로 침해사고 예방을 위한 보안패치, 접근통제 등 기술적 보호조치 적용을 강제 - 각 신재생에너지 시스템의 특성과 환경을 고려한 세부 보안 점검 체크리스트 제공을 통한 실효성 확보
원자력	원자력시설의 컴퓨터 및 정보시스템 보안	2024년 12월	- 원자력시설 내 필수 자산을 식별하고, 물리적·논리적 접근통제를 통해 제어시스템을 보호하도록 요구 - 사이버 공격의 예방, 탐지, 대응, 완화 및 복구 단계를 포함하는 심층방호 보호전략 수립 및 적용을 강제함
해양선박	해상 사이버보안 시스템 지침	2024년 6월	- 선박의 항해, 기관, 화물, 통신 시스템을 대상으로 사이버보안 등급을 정의하고, 사이버 공격 예방·탐지·대응 절차를 규정 - 선사 및 항만 운영자가 자체 보안계획을 수립하고, 정기적 모의훈련과 점검을 실시하도록 강제해 해양선박 보안 국제 표준과 연계된 관리 수준을 달성하도록 강제
전력망	스마트그리드 보안 요구사항	2024년 12월	- 발전·송전·배전·분산자원·수용가·전기차 충전·시장·운영·서비스 등 9개 영역별 참조모델을 기반으로 지능형 전력망 전 영역에 대한 보안 요구사항 제시 - 접근제어, 인증, 침해 대응, 통신보호 등 10대 분야 100여 개 보안 항목을 명시해 설계·운영 단계에서 통합적인 보안 관리가 이루어지도록 규정
제조	스마트공장 사이버보안 가이드	2019년 12월	- 접근통제, 데이터 보호, 안전한 상태 유지, 자산 관리 등 각 보안 영역별 세분화된 요구사항 제시를 통한 스마트공장 내 제어시스템과 생산설비의 보안 강화 - 사용자 계정 관리, 권한 분리, 무선 접근 통제, 네트워크 분리, 보안 로그 관리, 이상 징후 탐지 등 구체적 실행 지침을 포함
교통	스마트교통 사이버보안 가이드	2018년 5월	- 차량 내 ECU, 무선통신(DSRC, LTE/5G), 클라우드 서버, 모바일 단말기 등으로 구성된 스마트교통 서비스 환경에서 발생 가능한 위협을 식별하고 대응 방안을 제시 - 위협 유형은 서비스 거부(DoS), 데이터 위·변조, 중간자 공격, 무단 접근, 악성 프로그램 실행 등으로 분류되며, 이에 대한 인증, 접근통제, 암호화, 로그 관리, OTA 업데이트 검증 등 구체적 대응 방안 제시
에너지	스마트에너지 사이버보안 가이드	2019년 12월	- 에너지 도메인 내 구성 요소에서 발생 가능한 보안위협(예: 스마트미터 취약점 악용, ESS 제어정보 위·변조, EV 충전 데이터 탈취 등)을 식별하고, 기술적·관리적 보안 요구사항 제시 - 보안 요구사항은 기밀성, 무결성, 가용성, 부인방지를 기본 원칙으로 하며, 암호화, 접근통제, 로그 관리, 침입 탐지, 안전한 통신 규격 준수 등을 통해 서비스 안정성과 신뢰성을 확보

출처) 국내 산업별 보안 지침 저자 재구성

■ **국내 제로트러스트 사업은 표준화된 가이드라인과 IT 중심 시범사업을 기반으로 확산되고 있으나, OT 환경 대상 제로트러스트 적용 방안 및 실증 연구 필요**

- 과학기술정보통신부의 「제로트러스트 가이드라인 1.0 및 2.0」은 공공 및 민간기관의 제로트러스트 보안 모델 도입을 위해 단계별 성숙도 평가, 핵심 기능·세부역량 정의, 조직 내 역할과 도입 준비 방안 등을 구체적으로 제시
 - 4단계 성숙도 모델과 환경별 적용사례, 침투시험 기반 효과성 분석 등 실무 활용 가능한 내용을 포함
 - 각 기관은 이를 참고해 권한관리·접근제어·연속적 검증 등 제로트러스트 핵심 요소별 보안대책을 마련하고 실환경에 적용 가능
- 과학기술정보통신부와 한국인터넷진흥원(KISA)은 ‘제로트러스트 도입 시범사업’을 통해 금융, 클라우드, SaaS 등 IT 중심 영역에서 제로트러스트 모델 실증·확산을 지원
 - 총 6개의 선정 과제 수행을 통해 국내 민간기업의 실제 업무환경에 적합한 제로트러스트 보안 모델 개발 및 적용, 지속적인 운영·관리 수행

<표 20> 제로트러스트 도입 시범사업 선정 과제

번호	주관기관	사업명
1	SGA솔루션즈	• 금융 부문 모바일 개발환경 제로 트러스트 보안모델 도입 사업
2	프라이빗 테크놀로지	• 데이터 중심의 제로 트러스트 오버레이 금융망 구축
3	이니텍	• 인공지능(AI) 클라우드 인프라 보호를 위한 제로트러스트 시범사업
4	SK윌더스	• 서비스형 소프트웨어(SaaS) 환경 저변 확대에 따른 제로트러스트 기반의 보안 실증 사업
5	모니터랩	• 보안 서비스 에지(SSE) 플랫폼 기반 제로트러스트 보안 모델 실증
6	이스트시큐리티	• 제로트러스트 기반 범용 인증(클라우드 및 특수망) 접근제어 시스템 구축 사업

출처) 한국인터넷진흥원 보도자료, “KISA, 정보보호 기업과 함께 국민디지털 안전 강화”, 2025.05

- 국내에서는 시범사업 및 기업 솔루션 개발을 통한 IT 영역에서의 다양한 제로트러스트 적용사례가 축적되고 있으나, 산업제어망 등 OT 환경 특화 제로트러스트 적용·실증 사례가 거의 없어 적용 방안 및 실증 연구 필요
 - 예: 이스트시큐리티 컨소시엄은 공항철도를 수요기관으로 포함하였으나, 제어망 등 OT 환경이 아닌 5G 특화망에서의 인증·접근통제 기술 연구가 주요 목적임
 - 이에 따라 국가 기반시설을 포함하는 OT 환경 보호와 제로트러스트 보안 체계 실효성 검증을 위해 OT 환경 대상 제로트러스트 적용·실증 시범사업 추진이 필수적임

제5장 OT 특화 제로트러스트 적용 방안

5-1 OT ZT 핵심 원칙 및 고려 사항

- ▶ OT 환경에서의 제로트러스트는 실시간성·가용성 유지와 장비의 자율적 신뢰 판단 구조를 전제로 설계됨
- ▶ OT 특화 제로트러스트 핵심 원칙과 고려 사항을 도출하여 OT망에 적합한 제로트러스트 아키텍처 설계가 필요함

■ OT 환경에서 제로트러스트 아키텍처는 단순한 IT 보안 모델의 이식이 아닌, OT 고유 특성을 반영한 원칙 및 고려 사항 필요

- OT 환경에서는 ①인증·검증 및 패치 과정에서도 지연·중단 없이 동작하도록 안전장치와 이중화를 통해 실시간성과 가용성을 유지(실시간성·가용성 유지), ②외부 서버·네트워크 상태와 무관하게 현장 OT 장비가 최소한의 정책 판단과 자율적 신뢰 결정을 지속(OT 장비의 독립성 유지), ③공격자 내부 존재를 전제로 통신을 통제하고(OT·IT 전역에서의 침해 가정), ④결정적 트래픽 특성을 기반으로 지속적으로 상태를 감시해야 함(지속적 모니터링)

<표 21> OT 특화 제로트러스트 핵심 원칙

핵심원칙	설명
실시간성·가용성 유지	• 인증·검증 및 소프트웨어 패치 과정에서 지연이나 중단이 발생하지 않도록 안전 장치와 이중화 구조를 마련해야 함
OT 장비의 독립성 유지	• 현장 장비는 외부 서버나 네트워크 상태와 관계없이 최소한의 정책 판단 능력을 유지하며, 자율적으로 신뢰 결정을 지속할 수 있어야 함
OT·IT 전역에서의 침해 가정	• OT와 IT망 상관없이 공격자가 이미 내부에 있다고 전제하고, 마이크로세그멘테이션·DPI(Deep Packet Inspection)·이상 행위 기반 탐지 등을 통해 횡적 이동을 차단해야 함
지속적 모니터링	• OT 트래픽의 결정적 특성을 활용해 기준선을 마련하고, 이상 징후를 탐지할 수 있는 중앙 로그 관리·SIEM 체계를 마련해야 함

- OT 환경에 제로트러스트 적용을 위해서는 ①레거시 장비 제약 ②장비 기능 중심 보안 ③망분리와 접점 관리 ④문화적 요소 등 여러 가지 OT 환경의 고유한 특성을 고려해야 함

<표 22> OT 특화 제로트러스트 적용 고려 사항

고려 사항	설명
레거시 장비 제약	• 암호화·인증 미지원 장비에는 제로트러스트 기능을 직접 적용하기 어렵기 때문에, 상위 계층부터 단계적으로 확대하거나 게이트웨이 기반 보완 필요
장비 기능 중심 보안	• OT 환경에서는 단순한 네트워크 통제로는 이상 행위를 식별하기 어렵기 때문에 장비의 기능 단위별 정상 동작 범위를 기준으로 신뢰를 판단하는 기능 중심 보안 필요
망분리와 접점 관리	• 단순히 네트워크를 분리하는 것만으로는 안전하지 않으며, USB·원격 접속·업데이트 같은 모든 외부 연결 경로를 통제할 수 있어야 함
문화적 요소	• 기술적 통제와 더불어 OT 운영자 및 계약자에 대한 보안 인식 제고, 정책 준수 의무화가 병행되어야 제로트러스트가 정착 가능

5-2 OT ZT 적용 방안

- ▶ Purdue 모델 전 계층(Level 0~4)을 포괄하되, 국내 산업환경에 맞게 「제로트러스트 가이드라인 2.0」의 6대 핵심 요소를 기반으로 제로트러스트 요구사항을 제시하였으며, 추후 단계별 성숙도 모델로 발전시켜야 함

■ OT 환경에서 제로트러스트 아키텍처를 실현하기 위해서는 5.1절에서 제시한 핵심 원칙 및 고려 사항을 기반으로, 실제 운영 단계에서 어떻게 적용하고 성숙도를 높여갈 것인지에 초점을 두어야 함

- (핵심 목표) 운영 중단을 최소화하면서 단계적으로 기능을 도입하고, 기존 망분리·경계 보안을 제로트러스트 기반 통합 체계로 전환하여 OT 특수성을 고려한 보안·안전·가용성의 균형을 확보하는 것
- (6대 핵심 요소) 「제로트러스트 가이드라인 2.0」에서 제시한 핵심 요소를 기반으로, OT 환경 특성에 적합한 인증·검증 체계, 보안 장비 배치, 세분화 정책, 접근제어, 데이터 보호 기법 등을 구체화하여 단계별 성숙도 모델로 발전시킬 필요가 있음
 - 이는 IT망과 OT망을 병행 운영하는 조직에서 두 환경 간의 보안 정책 불일치와 관리 혼선을 최소화하기 위한 접근 방식으로, 특히 OT망을 중심으로 하되 IT망의 연계 특성을 함께 고려한 통합적 제로트러스트 운영체계 확립을 목표로 함
 - 특히, IT망을 통해 유입된 랜섬웨어가 OT망으로 확산되는 사례는 IT-OT 경계 구간의 단순 차단만으로는 대응이 어려우며, 6대 핵심 요소 기반으로 IT-OT를 동시에 아우르는 보안 기능을 적용하여 위험을 조기에 식별하고 피해 확산 방지 필요
 - 따라서 본 문서에서는 국내 IT 환경에서 지속적으로 활용되고 있는 제로트러스트 6대 핵심 요소와 2대 교차 역량을 참조하되 OT 환경의 특수성과 운영상의 요구를 함께 반영하여 IT와 OT를 통합적으로 포괄할 수 있는 제로트러스트 모델을 제시하였으며 그 핵심 구성으로 6대 핵심 요소를 선정함

- OT망에서는 Purdue 모델의 Level 0~4 전 구간을 아우르는 기술적 요소를 고려해야 하며, 각 계층에 적용할 수 있는 제로트러스트 기능 요구사항을 다음과 같이 제시

※ 본 요구사항은 보안성 강화를 위한 핵심 요소별 참고용 제시안으로 절대적인 요구사항은 아니며, 기관의 환경·위험 수준·운영 여건에 따라 탄력적으로 적용할 수 있어야 함

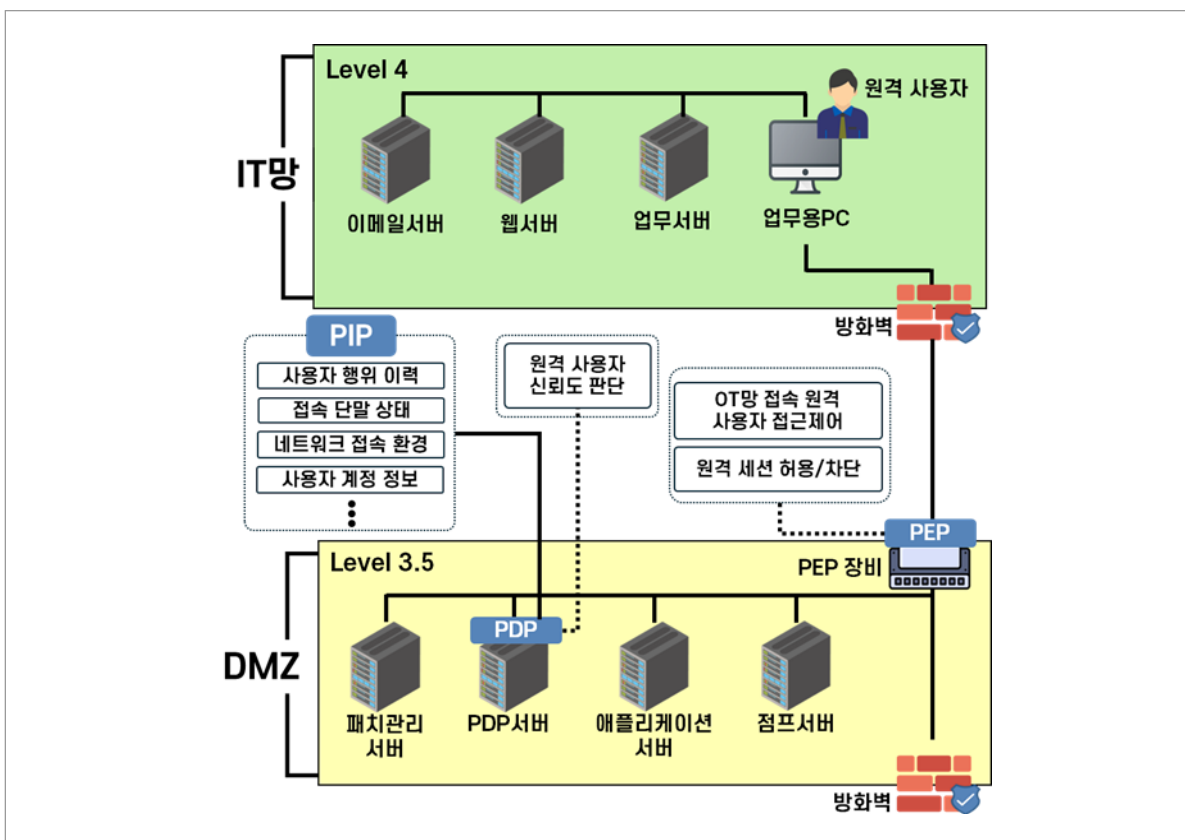
<표 23> OT 특화 제로트러스트 핵심 요소별 기능 요구사항

핵심 요소	요구사항 설명
식별자·신원	• OT 환경은 유지 보수 인력, 관리자 등 다수의 사용자 계정이 혼재되므로, IT망에서 운영자·관리자 계정에 대해 조직 차원의 IAM, MFA, 지속인증 등의 기술을 적용해 계정 탈취나 권한 오남용 방지 (Level 3.5~4) • OT 환경은 HMI, EWS 등 장비 로컬 로그인, 단순 패스워드 인증 등 제한적·폐쇄형 인증 수단에 의존하는 경우가 많고, 비밀번호 변경도 특정 상황에서만 수행되는 경우가 많아 인증 강도와 갱신 주기가 취약해지기 쉬움. 시스템 계정 및 공용 계정을 최소화하고 IAM·MFA 기반의 논리적 인증을 적용한 통합 인증체계를 단계적으로 도입 (Level 1~3)
기기 및 엔드포인트	• 원격 접속 단말, 온북 등 IT망에서 OT망으로 접속하는 기기에 대해 PKI 기반 보안 접속 및 EDR 적용 (Level 3.5~4) • HMI, 엔지니어링 워크스테이션 등 관리용 장비에는 중앙 집중적인 인증체계를 적용하며, 가용성으로 인해 인증 수단 적용이 어려운 장비에는 접근 로그 수집 및 SI 기반 이상행위 탐지 기반으로 보안성 강화 (Level 2~3) • OT 장비는 가용성과 실시간성을 중시하므로, 펌웨어 무결성 검증 및 서명 기반 업데이트 관리 등 최소한의 무결성 중심 보호 조치 유지 (Level 1~2) * Level 0 장비에는 현실적으로 보안 기능을 추가하기 어려움
네트워크	• 제어망과 정보망 사이의 시리얼 게이트웨이나 RTU 라우팅 구간은 공격의 이동 통로가 되기 쉬우므로 중요 구간(Zone)을 세분화하여 매크로세그멘테이션 적용 (Level 0~4) • 트래픽 패턴 기반 이상행위 탐지 및 DPI 기반 패킷 분석을 통한 프로토콜 오용·비정상 제어 명령·비인가 데이터 전송 등 사이버 공격 조기 식별 및 대응 체계 강화 (Level 0~4)
시스템	• SCADA, DCS, SIS 등 핵심 제어시스템을 대상으로 보안 아키텍처 구축 및 관리하고, 제로트러스트 정책을 이 구조 위에 통합 (Level 1~3) • 제어시스템은 상시 가동 특성상, 패치 및 취약점 점검은 오버홀(정기 정비) 기간에 계획적으로 수행 (Level 1~4)
애플리케이션 및 워크로드	• 제어 애플리케이션은 프로세스 제어 로직을 직접 다루므로, 제어 애플리케이션 및 운영 SW의 무결성 보장 (Level 2~3) • 업데이트·배포 시 SBOM 기반 안전성 확인 및 샌드박스 테스트 등 신뢰성 검증 절차 적용 (Level 3~4)
데이터	• 제어 명령 데이터 등 OT 환경 중요 정보에 대해서는 접근 권한 최소화 (Level 0~4) • 로그 및 운영 데이터는 사고 분석·이상 탐지를 위해 중앙집중식으로 수집·보존 (Level 0~4)

■ OT 환경에 제로트러스트 아키텍처를 실질적으로 적용하기 위해서는 적용 시나리오와 접근 주체 및 대상을 명확히 정의하고, 제로트러스트 아키텍처의 핵심 구성 요소인 정책시행지점(PEP), 정책결정지점(PDP)의 배치 방안을 설계하는 것이 중요

- OT환경은 Purdue 모델을 기반으로 환경이 구성되어 있기에, 이를 고려하여 제로트러스트 아키텍처 적용 시나리오를 도출해야 함
- Purdue 모델을 기반으로 PEP, PDP를 배치할 수 있는 여러 가지 시나리오가 도출될 수 있으며, 원격 사용자가 Purdue 모델 4레벨(IT망)에서 OT망으로 접근하려는 경우와 현장 사용자가 Purdue 모델 2~3레벨의 OT망의 제어시스템에 직접 접근하려는 경우 등의 시나리오를 고려할 수 있음
 - 아래 제시하는 시나리오는 예시일 뿐이며, OT망 구조·보안정책·운영 방식에 따라 PEP과 PDP의 배치 형태는 다양하게 설계될 수 있음
- (배치 시나리오 예시 1) Purdue 모델 4레벨(IT망)에서 접근하려는 사용자는 유지보수 인력, 외부접근 관리자 등이 있을 수 있으며 일반적으로 원격을 통해 OT망 접속 시도
 - IT망에서의 원격 사용자가 OT망에 접속을 하기 위해서는 DMZ망을 통해 원격 접속 인증을 받아야 하나 이는 일반적인 계정 인증 방식으로 지속적이고 동적인 사용자 접근제어는 하지 않는 구조임
 - 이에, IT망에서 방화벽을 거쳐서 접속을 시도하는 사용자는 ICAM, SDP와 같은 솔루션(PEP)을 통해 접근제어를 실시하며, 사용자에 대한 신뢰도 평가를 진행하는 PDP는 Level 3.5에 배치될 수 있음

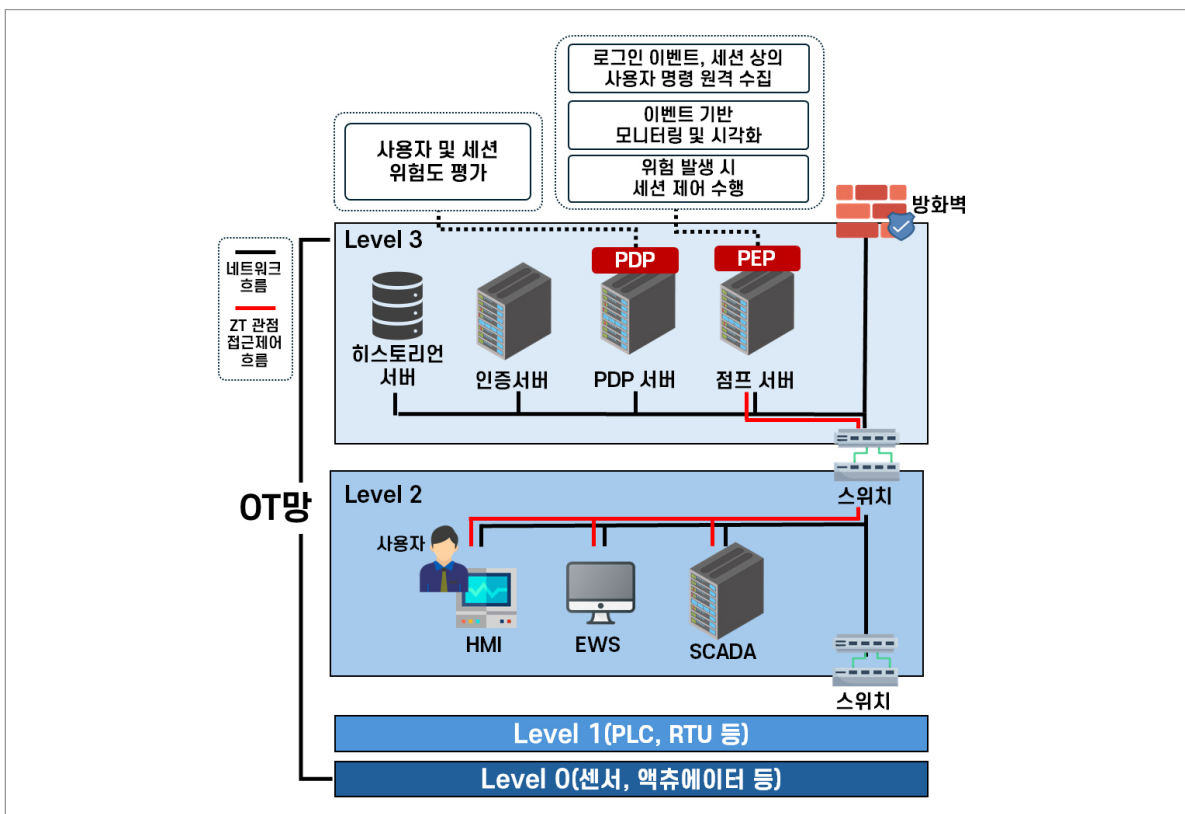
<그림 16> 제로트러스트 아키텍처 구성 요소 배치 시나리오 예시 1



출처) 저자 구성

- (배치 시나리오 예시 2) 제어망 내부에서 관리자, 유지보수 인력, 책임자 등과 같은 현장 사용자가 Purdue 모델 2~3레벨에 있는 OT 장비에 직접 접근 시도
 - HMI, SCADA 시스템 등과 같은 OT 장비에 직접 접근 시도하는 사용자는 일반적으로 로컬 계정 혹은 외부 인증 서버에서 관리하는 계정으로 접근
 - OT 장비들은 제로트러스트 관점에서의 실시간 세션 감시, 지속 인증 등을 위한 기능을 포함하고 있지 않아 별도 에이전트 혹은 프록시 형태로 구현해야 함. 그러나 일반적으로 OT 장비에는 에이전트를 설치하기가 어렵기 때문에, 상기 기능을 위해서 점프서버와 같이 프록시 역할을 하는 서버가 HMI 장비에 연동되는 구조가 현실적인 선택으로 보임
 - 이 경우, 점프서버가 HMI의 로그인 이벤트, 세션 상의 사용자 명령 등을 원격 수집하여 해당 정보를 기반으로 사용자 ID 기반 제로트러스트 정책을 수립하고, 이벤트 모니터링을 통하여 사용자 및 세션 위험도를 평가하며 특정 위험 명령 시 세션을 직접 제어하는 형태로 제로트러스트 아키텍처를 구축할 수 있음
 - 즉, 점프서버는 HMI 세션에 대한 원격 모니터링 및 PEP 역할을 수행하게 되며 여러 HMI에 대한 세션 모니터링이 가능하도록 적용한다는 전제하에 3레벨에 구축이 가능하고, PDP는 배치 모델에 따라 3레벨 혹은 3.5레벨 등에 구축 가능

<그림 17> 제로트러스트 아키텍처 구성 요소 배치 시나리오 예시 2



출처) 저자 구성

- 그 외 Purdue 모델 0~1레벨의 장비에 제로트러스트 철학을 적용하고자 하는 경우, 현실적으로 레거시 장비로 인해 보안 기능을 탑재하거나 실시간성·고가용성을 고려해야 하기 때문에 M2M(Machine-to-Machine) 인증 방식을 적용하는 최소한의 수준으로 접근할 수 있음

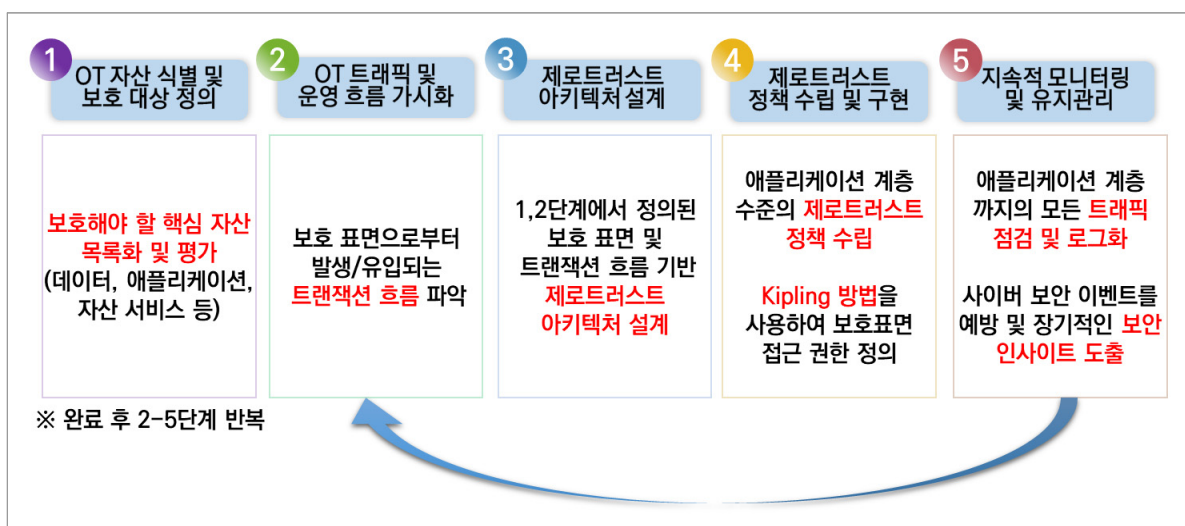
5-3 OT ZT 도입 로드맵

- ▶ OT 환경에서 제로트러스트는 일괄 구축이 아닌 소규모 보호 대상의 단계적 확장을 통해 안정성과 효율성을 함께 확보해야 함
- ▶ DAAS 및 Zone-Conduit 모델을 기반으로 업무영향분석(BIA)에 따라 우선 순위를 설정하고, 실제 환경에 맞는 정책시행지점(PEP)을 단계적으로 배치하여 정책의 실효성을 확보해야 함
- ▶ 정책 수립·운영 단계에서는 가용성과 안전성을 최우선으로 유지하되, 지속적 가시성과 자동화를 결합한 피드백 기반 모니터링 체계를 통해 제로트러스트 성숙도를 향상시켜야 함

■ CSA의 OT 환경에 맞춘 제로트러스트 도입 5단계 절차를 기반으로 OT/ICS 환경에 제로트러스트를 적용하기 위한 도입 로드맵을 제시

- CSA의 보고서는 OT 환경 제로트러스트 아키텍처 도입 전략을 Purdue 모델과 IEC 62443의 Zone-Conduit 개념을 고려해서 설계했다는 점에서 현실적인 실행 가능성을 갖춘 참조체계로 평가
- 해당 문서에서는 보호 대상을 작게 정의하고 반복적으로 확장하는 점진적 방식을 기본 원칙으로, 초기에는 제한된 범위에서 효과와 위험을 먼저 검증한 뒤 그 결과를 바탕으로 적용 범위를 단계적으로 넓힘

<그림 18> OT 환경에 적합한 제로트러스트 도입 로드맵



출처) 저자 재구성

■ 1단계: OT 자산 식별 및 보호 대상 정의

- OT 자산 식별 및 보호 대상 정의를 수행하면서, 초기부터 범위를 크게 잡지 않고 작은 보호 대상을 정해 이를 점증적으로 확장
 - 보유 중인 자산 관련 자료를 통합하여 목록화하고, 단순히 장비·애플리케이션뿐만 아니라 상호 연결, 사용 프로토콜, 인증 방식, 공급망·유지보수 의존성과 같은 메타데이터를 함께 기록

- ISA/IEC 62443의 Zone-Conduit 모델을 이미 운영 중이라면 현행 구역(Zone)을 보호 대상 정의의 출발점으로 삼고, 각 구역의 보호 대상은 DAAS 요소로 구체화

<표 24> DAAS 요소

요소	정의	예시
데이터 (Data)	산업 공정의 안전성, 신뢰성, 효율성에 직접적인 영향을 주는 중요한 운영 데이터를 포함	- 제어 신호 - 공정 매개변수 - 운영 이력 데이터, 구성/로직 파일(PLC·DCS) - 생산·품질 추적 데이터 - 펌웨어/패치 이미지
애플리케이션 (Applications)	중요한 비즈니스, 기능적, 운영적 요구사항을 충족시키는 소프트웨어, 하드웨어, 인프라의 집합	- 공정 및 생산 애플리케이션 - 엔지니어링 워크스테이션 도구 - 접근관리·권한 승인 시스템 - 원격지원 클라이언트 - OT 연계 SaaS/PaaS
자산 (Assets)	조직 내에서 데이터를 저장하거나 핵심 기능을 수행하는 리소스	- PLC/RTU/DCS/SIS - 현장 HMI·서버·워크스테이션 - 산업용 스위치·라우터·무선 AP - 원격접속 게이트웨이
서비스 (Services)	정보·운영 프로세스를 지속 제공·관리·보호하는 기술·업무 기능	- 원격 모니터링 - 취약점 관리, 가시성/분석 플랫폼 - 자동화·오케스트레이션 - 클라우드 기반 OT 지원 서비스

출처) CSA, "Zero Trust Guidance for Critical Infrastructure"

- 우선 순위 결정은 위협평가보다 업무영향분석(BIA)을 먼저 적용하여 생산중단, 안전, 규제 준수, 품질에 대한 파급효과로 가늠
 - 위험도가 낮은 대상을 시범 보호 대상으로 선정하여 초기 적용 후, 결과를 기반으로 정의 범위를 정제하고 점차 세분화·확대
 - 과정이 진행될수록 정확하고 실시간에 가까운 자동화된 목록으로 운영
- 보호 대상 요소별 성숙도 목표를 설정하고, 현재 수준과의 격차 분석을 통해 우선 순위를 설정함으로써 중단기 계획 수립과 지속적 보안 수준 향상을 달성해야 함

■ 2단계: OT 트래픽 및 운영 흐름 가시화

- 보호 대상 간 실제 통신·업무 흐름을 식별·기록하여 효과적인 제어 지점을 도출하는 단계로, 운영·공정·제어 흐름을 종합적으로 파악하는 것이 핵심임
- ISA/IEC 62443의 Zone-Conduit 모델을 기반으로 영역 간 통신 경로를 정리하고, 이를 바탕으로 허용 기준선을 수립하여 제어 지점 후보를 도출해야 함

- 관찰된 트래픽뿐 아니라 정책상 허용되었으나 현재 사용되지 않는 흐름도 포함하여 목록화
- 각 흐름별로 통신 목적, 데이터 민감도, 프로토콜/포트, 출발·종단 지점, 주기·지연 요구, 보안 적용 현황을 함께 기록
- 다만 실제 OT/ICS 현장에서는 Zone-Conduit 매핑만으로는 운영 흐름을 충분히 가시화하기 어렵다는 한계가 존재함
 - 제어 및 필드 계층(PLC, 센서 등)은 감시 장비나 관리형 스위치가 부재한 경우가 많아 세부 트래픽 수집이 어려움
 - 평면망 구조가 여전히 많아 특정 지점에서 트래픽을 집중적으로 관찰하기 곤란
 - 설비 내부에서만 발생하는 제어 흐름은 외부 장비로 확인 불가
- 따라서, 실제 OT/ICS 현장에서는 더 세분화한 구성 요소 정의가 필요하며, 다음과 같은 보안 접근이 요구됨
 - 설치 가능한 자산에는 가능한 범위 내에서 에이전트 배치
 - 에이전트 설치가 어려운 구간에는 관리형 스위치(SPAN/TAP), 프로토콜 인지형 센서, 전용 모니터링 장비를 활용
 - 전담 인력이 부족한 중소 사업장은 클라우드 연계형 OT 가시성 관리 플랫폼이나 SIEM/SOC 연동 자동화 관제를 점진적으로 도입할 필요가 있음

■ 3단계: 제로트러스트 아키텍처 설계

- 앞선 두 단계에서 확보한 자산·흐름 정보를 기반으로, 아키텍처 내에서 제로트러스트 정책을 적용할 수 있는 정책시행지점(PEP)을 식별하는 단계임
 - 최신 OT 환경에서는 소프트웨어 에이전트 기반 PEP 배치가 용이하므로, 엔터프라이즈 IT 네트워크(Purdue 모델 4레벨 이상), IT-OT 간 DMZ(3.5레벨), OT/ICS 애플리케이션 서버·데이터베이스·엔지니어링 워크스테이션·HMI 등이 위치한 제어/처리 네트워크(2~3레벨)를 중심으로 소프트웨어 기반 PEP 적용이 가능함
 - 반면, Purdue 모델 하위 레벨(0~1레벨)은 PLC, RTU, 센서 등 레거시 장비가 다수 포함되어 소프트웨어 에이전트 설치가 어렵기 때문에 직접적인 PEP 배치가 제한됨
 - 이 경우 OSI 2~7계층 수준에서 네트워크 인프라 계층을 활용한 정책 시행으로 보완해야 하며, 이는 OT 환경이 요구하는 고가용성·실시간성을 고려하여 설계되어야 함
 - 특히 소프트웨어 클라이언트를 설치할 수 없는 자산에 대해 OSI 7계층 정책을 적용하려면 트래픽을 프록시 기반으로 심층 검사할 필요가 있지만, OT/ICS 특수 프로토콜·이기종 장비 구조로 인해 현실적으로 어려움이 있어 라우팅 규칙 중심의 OSI 3계층 정책 또는 VLAN/VRF 기반 가상 네트워크 분리가 더 실용적인 방식으로 평가됨
- 소프트웨어 에이전트를 지원하는 자산은 정책시행지점(PEP)으로 고려할 수 있으며, 이는 다음 영역에 적용 가능함
 - 엔터프라이즈 IT 네트워크(Purdue 모델 4레벨 이상)
 - IT/OT 네트워크 사이의 DMZ(Purdue 모델 3.5레벨)
 - OT/ICS 애플리케이션 서버, 데이터베이스, 데이터 저장 서버, HMI, 엔지니어링 워크스테이션이 위치한 제어 및 처리 네트워크(Purdue 모델 2~3레벨)

- Purdue 모델의 하위 레벨(0~1)과 같이 소프트웨어 에이전트 설치가 불가능한 경우에는 다음과 같이 네트워크 및 인프라 차원에서 보완할 수 있는 대체 방안이 필요
 - OT/ICS에 적합한 방화벽 기반 정책을 통한 OSI 3계층~7계층 세분화
 - SDN, VRF 등 가상 네트워크 솔루션을 활용한 OSI 3계층~7계층 세분화
 - OT/ICS 라우터 또는 라우팅 스위치를 통한 OSI 2계층~4계층 세분화
 - 특수 LAN 마이크로세그먼트 게이트웨이 도입을 통한 OSI 2계층~3계층 세분화
 - 단방향 게이트웨이 또는 데이터 다이오드 도입을 통한 OSI 1계층~2계층 세분화

■ 4단계: 제로트러스트 정책 수립 및 구현

- 앞선 아키텍처 설계를 기반으로, 실제 접근제어 정책을 개발·적용하는 단계
- OT 환경은 인명 안전과 고가용성이 핵심이므로, 동적 정책 변경 시 세션을 즉시 종료하기보다 운영 연속성을 보장하는 정교한 제어 필요
 - 경계 구간에서는 화이트리스트 정책을 유지하되, 내부 구간에서는 안전성 확보를 위해 제한적 허용 정책(Approved Exception)이 병행될 수 있음
- 정책 수립의 핵심은 신원과 맥락을 기준으로 한 접근 통제
 - 사용자·장치 신원은 접근 속도와 보안성의 균형을 유지해야 하며, 인증 실패 시 가용성에 미치는 영향을 고려해 제한 기능 모드, 승인 기반 임시 접근 등 대체 절차를 마련해야 함
- 레거시 OT 장비처럼 개별 사용자 추적이 어려운 환경은 보완 통제 필요
 - 구성 관리 도구로 시스템 변경 내역 감시
 - 개인 계정 사용 불가 시 그룹 계정을 사용하되, 주기적 비밀번호 변경·사용 범위 제한 적용
 - 물리적 출입 통제로 시스템 접근을 제한·기록하고, 필요 시 카메라 등 추가 모니터링 수단 운영
 - 외부 접점 구간에서는 보안 장치와 마이크로세그멘테이션을 결합해 방어 체계를 강화하고, 필요 시 물리적·논리적 보안을 동시 적용
- 정책 표현은 Kipling 방법*으로 일관되게 기술하며, 이 방법은 자산별 보안 경계를 정밀하게 설계하기 위한 정책의 틀 제공
 - * 문제 분석 시 6하 원칙을 활용하여 검토하는 기법으로, 국내에서는 보통 '5W1H 기법'으로 쓰임
 - 누가(Who): 자산에 접근할 수 있는 인증된 사용자·장치·엔티티 정의
 - 무엇을(What): 접근이 허용된 애플리케이션 및 서비스 명시
 - 언제(When): 접근이 가능한 시간·상황·조건 설정
 - 어디서(Where): 접근이 허용된 서버, 데이터베이스, 네트워크 구간 식별
 - 왜(Why): 접근 요청의 목적·업무 사유 규정
 - 어떻게(How): 접근 시 사용하는 인증 방식, 통신 절차, 암호화 표준 명시

■ 5단계: 지속적 모니터링 및 유지관리

- 이 단계의 목적은 제로트러스트를 상시 운영 체계로 전환하여 이상 징후를 조기에 탐지하고, 변화에 맞춰 설계·정책을 주기적으로 갱신하는 데 있음
 - 네트워크 트래픽, 사용자 행위, 장치 활동을 준실시간으로 분석해 비정상 패턴을 식별하고, 정기적인 보안 점검과 침투 테스트로 취약점을 선제적으로 확인
- 가시성과 데이터 수집은 수집 지점, 전송 및 저장 방식의 명확한 정의에서 출발
 - 식별된 자산과 데이터 경로를 어떤 방식으로 모니터링할지, 수집 데이터를 어디로 전송·저장할지 계획해야 하며, 일반 IT 도구의 한계를 보완하기 위해 OT 특화 모니터링 도구를 병행
- 취약점 관리는 패치 적용이 제한적인 현실을 고려하여, 문맥 기반 평가·모니터링·완화 통제에 초점을 두어야 함
 - 인증되지 않은 엔티티가 장비 존재 자체를 식별하지 못하도록 네트워크 은닉·세분화·기본 거부 정책 유지
 - 필요 시 단방향 게이트웨이 등 물리적 분리를 병행해 패치 지연에 따른 노출을 최소화
- 주기적 재검토를 통해 단계별 산출물을 순환적으로 업데이트
 - 자산 변경 시 1단계 보호표면 정의 갱신 및 승인 절차 연계
 - 접근 요구 변경 시 2단계 운영 흐름 재매핑
 - 기술·시나리오 변화에 따른 3단계 아키텍처, 4단계 정책 문서 갱신 및 공급업체 적합성 재평가
 - 마지막으로 사고 대응·모니터링·취약점 관리 프로세스를 지속 평가·개선하여 운영 품질 유지



제6장 결 론

■ OT는 발전소, 원자력 등 국가 핵심 인프라 운영에서 중요한 역할을 하고 있으며 사이버 공격 발생시 대규모 물리적 피해와 사회적 혼란 가능성이 있어 OT 보안은 국가 안보와 직결됨

- 기존 망분리 중심 보안체계는 AI·클라우드 도입, 원격 유지보수 확대 등으로 외부 접점이 늘어나면서 한계를 드러내고 있으며, IT망 침해가 OT망으로 전이되는 사례 및 OT망에 대한 직접 침투 등 고도화된 위협에 대응해야 함
- 이러한 사례는 OT 보안이 기업의 경영 위험을 넘어 국가 기반시설의 안정적 운영을 위협할 수 있음을 보여주며, 내부 침투를 가정하여 보안을 강화하는 제로트러스트 철학을 반영한 국가 차원의 OT ZT 전략 도입 필요

■ 미국은 OT 보안 관점에서 제로트러스트 적용이 필수적임을 이해하고 일부 도메인에서 도입·구현 가이드를 마련 중이며, 기업들도 OT 제로트러스트를 위한 기술·솔루션 개발 및 업체 간 협력을 통한 실증 사업 진행 중

- 미국은 NIST가 발표한 「Guide to Operational Technology (OT) Security (SP 800-82 r3)」을 통해 OT 네트워크에서 보안 향상 방안에 대해 제시
 - IT와 OT 장비를 권한·신뢰 수준·기능 중요도·데이터 흐름에 따라 구분·세분화하도록 하고, Purdue 모델·ISA-95·IIoT 아키텍처 등을 활용할 수 있도록 안내
 - DMZ·방화벽·라우터·데이터 다이오드를 통한 통신 경계 설정 및 IDS/IPS·SIEM·행위 기반 탐지를 통한 이상 징후 분석 등 실행 방안을 강조
 - 네트워크 보안성을 향상시키기 위해 제로트러스트 보안 아키텍처를 상위 계층(Purdue 모델 Level 3~4) 장비에 우선 적용하는 등 현실적 적용 방안을 제시
- 민간의 경우, ZT에 관한 다양한 가이드 문서를 발간해 온 CSA에서 중요 기반시설을 위한 제로트러스트 가이드언스를 발간
 - 점프 호스트·네트워크 세분화·상태 기반 접근제어 등을 통해 OT 제로트러스트 구현 전략 구체화
 - OT·ICS 환경에서의 제로트러스트 적용을 위한 5단계 절차를 제시하고, 이를 통해 SANS의 주요 통제 항목을 강화할 수 있음을 강조

- 미 국방부는 볼트 타이퐁 등 최신 OT 위협에 대응하기 위한 OT 제로트러스트 전략을 준비하고 있으며, 미 공군의 Spangdahlem 기지에서는 'Project BlastWave'를 통해 제로트러스트 기반 OT 보안 솔루션을 상하수 처리시설에 적용하는 시범사업 수행
 - 기존 IT 환경에서의 ZT 전략과 유사한 틀을 유지하되 가용성을 중시하는 접근법으로 활동 수를 91개에서 35~40개로 축소하여 현실성을 높임
 - 'Project BlastWave'는 BlastWave가 주도하는 OTZTA(Operational Technology Zero Trust Alliance)의 핵심 과제이며, Nozomi Networks, Booz Allen Hamilton, DarkTrace 등 다수의 민간 기업 참여

■ EU·일본·싱가포르 등 여러 글로벌 국가들도 ZT를 명시적으로 언급하고 있지 않으나 법·제도적 장치를 통해 OT 보안을 강화하는 추세

- EU는 「NIS2 Directive」를 통해 에너지·교통·보건 등 핵심 서비스 사업자에 사이버보안 및 위험관리 의무를 부과, 불이행 시 과징금을 부과하는 강력한 규제 체계를 마련
- 일본은 경제산업성(METI)과 디지털청을 중심으로 산업제어시스템 보안 가이드라인을 발간하고, 민간·지자체에 적용을 확산하여 제도적 기반을 강화
- 싱가포르는 「Cybersecurity Act 2018」과 「CCoP 2.0」을 통해 중요 정보통신기반시설 운영자에게 최소 보안 요건을 준수하도록 규정하고, 법적 근거 하에 정기 감사와 보고 체계를 운영

■ 한국도 기반시설 보호 제도 보완, 제로트러스트 요소를 반영한 OT 보안 강화 기술·정책·가이드 개발 등을 통하여 고도화된 공격 대응 역량 확대 필요

- 한국도 「주요정보통신기반시설 보호법」을 통해 핵심 인프라 보호를 추진 중이나, 기반시설 지정·보호계획 수립 중심으로 운영되고 있어 변화하는 OT 위협 환경에 대응하기에는 한계가 있음
- 따라서 정부·산업계·학계가 공동으로 OT 환경에서의 이상징후 탐지, 사고 대응, 복원력 강화 등 OT 보안을 위한 기술 연구개발 추진 필요
 - 생성형 AI·클라우드 등 신기술 확산 및 공격 기술의 다변화·고도화에 따라 IT-OT 융합 환경의 공격 표면이 넓어지는 만큼, 제로트러스트 기반 기술적 대응 역량 확충 필요
- 또한 OT 현장에서 보안 아키텍처를 구축하는 과정에서 제로트러스트 철학이 기본적으로 반영될 수 있도록, OT 내부 공격 대응 시나리오, ZT 도입 절차, 성숙도 모델 및 참조 사례 등을 포함하는 OT 제로트러스트 가이드 등 정책문서 발간 필요
 - 정부·산업계·학계 간 협력 체계 구축, 표준화된 OT 보안 프레임워크 마련 및 고도화, 제로트러스트 원칙에 부합하는 가이드 발간 및 보안체계 도입 등을 공동으로 노력해야 함

용어 정의

용어	정의
운영 기술 (OT, Operational Technology)	• 물리적 환경과 상호작용하거나 이러한 장치를 관리하는 다양한 프로그래밍 가능한 시스템 및 장치. 이러한 시스템과 장치는 장치, 프로세스 및 이벤트의 모니터링 및/또는 제어를 통해 직접적인 변화를 감지하거나 유발하며, 이러한 예로는 산업 제어 시스템, 건물 자동화 시스템, 교통 시스템, 물리적 접근 제어 시스템, 물리적 환경 모니터링 시스템 및 물리적 환경 측정 시스템이 있음 (출처: NIST SP 800-82r3) • 산업 장비, 자산, 공정 및 사건을 직접 모니터링 및/또는 제어함으로써 변화를 감지하거나 유발하는 하드웨어 및 소프트웨어 (출처: 가트너 IT 용어 사전)
접근 주체 혹은 주체 (Subject)	• 사용자와 애플리케이션(혹은 서비스), 기기의 조합이며, 여기에 악의적인 공격자 혹은 불법적인 애플리케이션, 감염된 기기 등이 포함될 수 있음 (출처: 과기정통부 제로트러스트 가이드라인 1.0)
정책결정지점 (PDP, Policy Decision Point)	• 접근 주체가 리소스에 접근할 수 있는지를 최종적으로 결정하여 이를 정책시행지점(PEP)에게 명령하는 논리적 개체로, 정책 엔진(PE)과 정책 관리자(PA)로 구성 (출처: 과기정통부 제로트러스트 가이드라인 1.0)
정책 관리자 (PA, Policy Administrator)	• 접근 주체와 리소스 사이의 통신 경로를 생성하거나 취소하기 위한 결정을 정책시행지점(PEP)에게 전달하는 논리 개체 (출처: 과기정통부 제로트러스트 가이드라인 1.0)
정책 엔진 (PE, Policy Engine)	• 접근 주체가 리소스에 접근할 수 있는지를 최종적으로 결정하는 논리적 개체로, 정책정보지점(PIP)으로부터 신뢰도를 평가할 수 있는 알고리즘에 대한 입력을 수신하여, 현재 리소스 접근 요청을 승인하거나 거부 혹은 현재 연결 중인 상태의 접근을 취소할 수 있음 (출처: 과기정통부 제로트러스트 가이드라인 1.0)
정책시행지점 (PEP, Policy Enforcement Point)	• 접근 주체와 리소스 사이를 연결하고 모니터링하며 최종적으로 연결을 종료하는 논리적 개체로, PDP의 정책 관리자에게 접근 요청을 전달하고 접근 승인 여부를 전달받아 현재 접근 세션에 직접 반영 (출처: 과기정통부 제로트러스트 가이드라인 1.0)

용어	정의
정책정보지점 (PIP, Policy Information Point)	정책결정지점이 정책 결정을 내리는 데 활용하기 위해서 수집한 사용자, 기기 관련 정보 및 기타 정책 관련 정보를 제공하는 논리적 개체로, 이러한 정보에는 기업이 생성하거나 제어하지 않는 외부 데이터와 기업 내부적으로 생성되는 내부 데이터로 분류할 수 있으며 규제·내부규정, 데이터 접근 정책, 보안 이벤트, 위협 인텔리전스, 사용자 및 기기 인증 정보, 네트워크 및 시스템 상의 행위 로그 등을 포함할 수 있음 (출처: 과기정통부 제로트러스트 가이드라인 1.0)
제로트러스트 (Zero Trust)	위협이 언제 어디서든 발생 가능하다는 인식하에 기업 내부의 네트워크, 시스템 혹은 리소스에 접근하고자 하는 어떤 사용자·기기에 대해서도 지속 인증, 세밀한 접근제어를 통한 최소 권한 부여 등 적극적인 신뢰도 평가 없이 접근을 허용하지 않는 보안 모델 및 이를 구현·실체화하기 위한 아이디어의 집합을 의미 (출처: 과기정통부 제로트러스트 가이드라인 1.0)
제로트러스트 아키텍처 (Zero Trust Architecture)	제로트러스트의 개념을 활용하여 기업 내부의 네트워크, 시스템 및 리소스를 보호할 수 있는 추상적인 보안 구조이며 해당 목적을 달성하기 위한 기업망의 구성 요소, 구성 요소 간 인터페이스 정의와 인증, 접근제어, 보안 모니터링 및 가시화 등 보안 정책을 포함 (출처: 과기정통부 제로트러스트 가이드라인 1.0)
퍼듀 모델 혹은 퍼듀 엔터프라이즈 참조 아키텍처 (Purdue Model or Purdue Enterprise Reference Architecture)	Purdue 대학에서 1990년대 초 개발한 모델로, ICS 환경을 여러 레벨로 계층화하여 제어 영역과 비즈니스 네트워크 간의 경계를 명확히 정의하는 산업제어시스템 참조 아키텍처 (출처: 미 에너지부, "Purdue model framework for industrial control systems & cybersecurity segmentation")
구역-통신경로 모델 (Zone-Conduit Model)	산업제어시스템을 보안 구역(Zone)으로 나누고, 각 구역 간의 통신경로를 Conduit으로 정의하여 경계와 제어 지점을 설정하는 모델 (자체 정의)
구역 (Zone)	자산의 중요성, 운영 기능, 물리적/논리적 위치, 필수 접근(예: 최소 권한 원칙)이나 담당 조직과 같은 기준을 적용하거나 리스크를 적용한 논리적/물리적 자산의 그룹핑 (출처: KS X IEC 62443-3-2:2020)
통신경로 (Conduit)	2개 이상의 구역을 연결하는 공통 보안 요구사항을 공유하는 통신 채널의 논리적 그룹 (출처: KS X IEC 62443-3-2:2020)
원격 정보 수집 및 제어 시스템 (SCADA, Supervisory Control And Data Acquisition)	- 원격지에 설치된 단말에서 데이터를 수집하고 중앙 감시 센터에 전송하여 현장 상황을 온라인으로 감시 제어하는 시스템. 발전, 송배전 시설, 석유 화학 플랜트, 제철 공정 시설, 공장 자동화 시설 같은 여러 종류의 원격지 시설 장치를 중앙 집중식으로 감시 제어 (TTA 용어 사전) - 광범위하게 분산된 자산을 원격에서 모니터링·제어하기 위한 시스템으로, 전력 송배전망, 수자원, 가스·오일 유통, 대규모 인프라 관리에 주로 사용. 일부 발전·산업 시설에서는 SCADA가 보조 감시계층으로 사용되기도 함 (자체 정의)

참고문헌

- [1] IEC 61850-5 Edition 2, "Communication networks and systems for power utility automation – Part 5: Communication requirements for functions and device models", IEC International Standard, 2013.01.
- [2] European Parliament & Council of the European Union, "Directive (EU) 2016/1148 of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union (NIS Directive)", 2016.07.
- [3] 한국정보통신기술협회, "산업제어시스템 보안요구사항 – 제1부: 개념 및 참조모델", TTA.KO-12.0307-Part1, 2017.06.
- [4] 한국정보통신기술협회, "산업제어시스템 보안요구사항 – 제2부: 현장장치 계층", TTA.KO-12.0307-Part2, 2017.06.
- [5] 한국정보통신기술협회, "산업제어시스템 보안요구사항 – 제3부: 제어 계층", TTA.KO-12.0307-Part3, 2017.06.
- [6] 한국정보통신기술협회, "산업제어시스템 보안요구사항 – 제4부: 운영 계층", TTA.KO-12.0307-Part4, 2017.06.
- [7] 한국인터넷진흥원, "스마트교통 사이버보안 가이드", 2018.05.
- [8] 싱가포르 사이버보안청(CSA), "Cybersecurity Code of Practice for Critical Information Infrastructure", 2018.07.
- [9] Hydeo, "Cyber-attack on Hydro", 2019.03.
- [10] David Garton, "Purdue model framework for industrial control systems & cybersecurity segmentation." Working document of the NPC Study, US Department of Energy Topic Paper #4-14, 2019.11.
- [11] 한국인터넷진흥원, "스마트공장 사이버보안 가이드", 2019.12.
- [12] 한국인터넷진흥원, "스마트에너지 사이버보안 가이드", 2019.12.
- [13] Zack Whittaker, "Honda global operations halted by ransomware attack", TechCrunch, 2020.06.
- [14] 일본 경제산업성(METI), "공장 시스템을 위한 사이버/물리 보안 가이드라인(Cyber/Physical Security Framework for Factory Systems)", 2020.11.
- [15] 서정택, "OT 사이버보안위협 및 대응방안", G-PRIVACY 2021 컨퍼런스 발표자료, 2021.04.
- [16] 과학기술정보통신부, "주요정보통신기반시설 취약점 분석·평가 기준", 2021.12.
- [17] Reuters, "Toyota suspends domestic factory operations after suspected cyber attack", 2022.03.
- [18] Keith Stouffer 등, "Guide to Operational Technology (OT) Security", NIST SP 800-82 Rev. 3, 2022.04.
- [19] SEMI, "SEMI E187: Specification for Cybersecurity of Fab Equipment", 2022.07.
- [20] 싱가포르 사이버보안청(CSA), "CYBERSECURITY CODE OF PRACTICE FOR CRITICAL INFORMATION INFRASTRUCTURE – SECOND EDITION REVISION ONE", 2022.11.
- [21] U.S. NRC, "Zero Trust for Operational Technology Literature Review", TLR-RES-DE-2023-001, 2022.11.

- [22] European Parliament & Council of the European Union, “Directive (EU) 2022/2555 of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive)”, 2022.12.
- [23] 국가정보원, “국가정보보안기본지침”, 2023.01.
- [24] Anna Ribeiro, “Ransomware attack temporarily shuts down Dole production, disrupts food supplies”, IndustrialCyber, 2023.02.
- [25] 박현재, “Colonial Pipeline Ransomware attacker address tracking”, 2023.04.
- [26] 과학기술정보통신부 등, “제로트러스트 가이드라인 1.0”, 2023.07.
- [27] 데이터넷, “[OT보안2023 설문] OT 조직 56% “OT 보안 계획 아직 없어”, 2023.10.
- [28] Jacob Benjamin, “OT Cybersecurity Breach Disrupts Operations at the Port of Nagoya, Japan”, 2023.11.
- [29] U.S. NRC, “Zero Trust Architectures for Operational Technology at Nuclear Facilities”, TLR-RES-DE-2024-001, 2023.11.
- [30] 싱가포르 사이버보안청(CSA), “Operational Technology Cybersecurity Masterplan 2024”, 2024.01.
- [31] 뉴스1, “중해커 최소 5년간 美인프라 잠입…기밀탈취 대신 '사회혼란' 목적”, 2024.02.
- [32] Spangdahlem Air Base Public Affairs, “Spangdahlem AB becomes first DoD installation to implement BlastWave cyber security solution”, 2024.03.
- [33] Fortinet, “2024 State of Operational Technology and Cybersecurity Report”, 2024.06.
- [34] 한국선급, “해상 사이버보안 시스템 지침”, 2024.06.
- [35] IEC 62443-2-1:2024, “Security for industrial automation and control systems – Part 2-1: Security program requirements for IACS asset owners”, IEC International Standard, 2024.08.
- [36] CSA, “Zero Trust Guidance for Critical Infrastructure”, 2024.10.
- [37] 보안뉴스, “OT 환경 노리는 랜섬웨어 공격이 증가하고 있는 가운데, CISO의 할 일은?”, 2024.10.
- [38] 과학기술정보통신부 등, “제로트러스트 가이드라인 2.0”, 2024.12.
- [39] 한국정보통신기술협회, “스마트그리드 보안 요구사항”, TTA-KO-12.0182/R1, 2024.12.
- [40] 한국원자력통제기술원, “원자력시설의 컴퓨터 및 정보시스템 보안”, RS-015, 2024.12.
- [41] 데이터넷, “[OT보안②] 사회 전체 피해 입히는 OT 타깃 공격”, 2024.11.
- [42] U.S. NRC, “Implementing Zero Trust for Operational Technology at Nuclear Facilities”, TLR-RES-DE-2025-001, 2025.02.
- [43] MeriTalk, “DoD’s OT Zero Trust Strategy Under Review, Expected by August”, 2025.03.
- [44] 국가정보원, “국가·공공기관 신재생에너지 보안가이드라인 및 체크리스트”, 2025.03.
- [45] 한국인터넷진흥원 보도자료, “KISA, 정보보호 기업과 함께 국민 디지털 안전 강화”, 2025.05.
- [46] Fortinet, “2025 State of Operational Technology and Cybersecurity Report”, 2025.07.
- [47] MeriTalk, “Pentagon to Release Updated Zero Trust Strategy by End of Year”, 2025.09.
- [48] Inside Defense, “DIU looking for non-kinetic tech to stop small 'suspect' watercraft in U.S. territorial waters”, 2025.09.
- [49] DoD, “Executive Summary: Zero Trust for Operational Technology”, 2025.11.
- [50] Microsoft, “Defender for IoT and your network architecture”, <https://learn.microsoft.com/en-us/azure/defender-for-iot/organizations/best-practices/understand-network-architecture>

저자

• **한국인터넷진흥원(KISA)**

– 정책연구실 이익섭 실장, 신기술대응팀 이재형 팀장, 이해진 책임, 이재혁 주임

• **가천대학교**

– 서정택 교수, 이석준 교수

OT Operational
Technology **환경의**
제로트러스트 적용 안내서